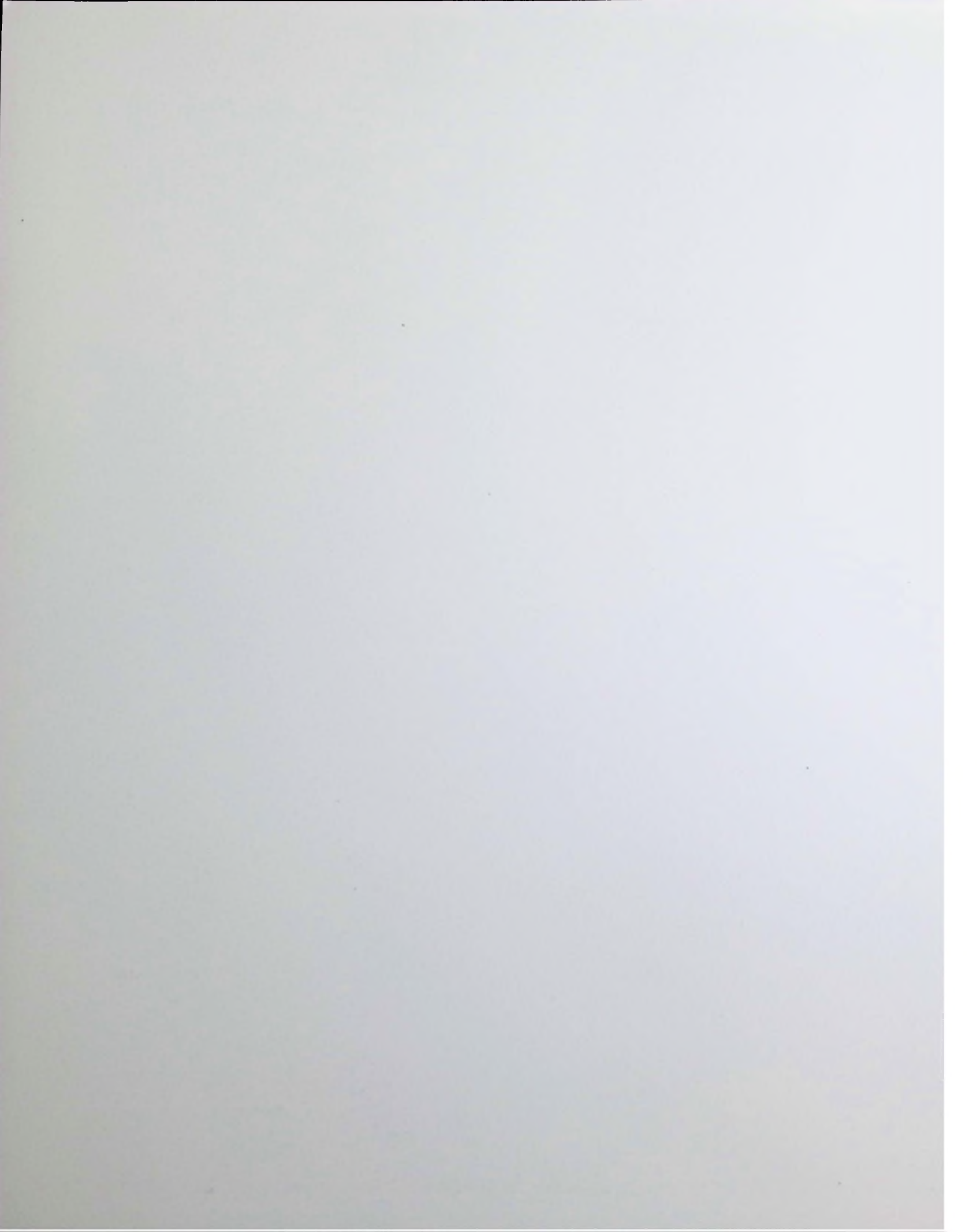




Copyright © 2017, Ed Skoudis and John Strand. All rights reserved to Ed Skoudis and John Strand and/or SANS Institute.

PLEASE READ THE TERMS AND CONDITIONS OF THIS COURSEWARE LICENSE AGREEMENT ("CLA") CAREFULLY BEFORE USING ANY OF THE COURSEWARE ASSOCIATED WITH THE SANS COURSE. THIS IS A LEGAL AND ENFORCEABLE CONTRACT BETWEEN YOU (THE "USER") AND THE SANS INSTITUTE FOR THE COURSEWARE. YOU AGREE THAT THIS AGREEMENT IS ENFORCEABLE LIKE ANY WRITTEN NEGOTIATED AGREEMENT SIGNED BY YOU.

With the CLA, the SANS Institute hereby grants User a personal, non-exclusive license to use the Courseware subject to the terms of this agreement. Courseware includes all printed materials, including course books and lab workbooks, as well as any digital or other media, virtual machines, and/or data sets distributed by the SANS Institute to the User for use in the SANS class associated with the Courseware. User agrees that the CLA is the complete and exclusive statement of agreement between The SANS Institute and you and that this CLA supersedes any oral or written proposal, agreement or other communication relating to the subject matter of this CLA.

BY ACCEPTING THIS COURSEWARE, YOU AGREE TO BE BOUND BY THE TERMS OF THIS CLA. BY ACCEPTING THIS SOFTWARE, YOU AGREE THAT ANY BREACH OF THE TERMS OF THIS CLA MAY CAUSE IRREPARABLE HARM AND SIGNIFICANT INJURY TO THE SANS INSTITUTE, AND THAT THE SANS INSTITUTE MAY ENFORCE THESE PROVISIONS BY INJUNCTION (WITHOUT THE NECESSITY OF POSTING BOND), SPECIFIC PERFORMANCE, OR OTHER EQUITABLE RELIEF.

If you do not agree, you may return the Courseware to the SANS Institute for a full refund, if applicable.

User may not copy, reproduce, re-publish, distribute, display, modify or create derivative works based upon all or any portion of the Courseware, in any medium whether printed, electronic or otherwise, for any purpose, without the express prior written consent of the SANS Institute. Additionally, User may not sell, rent, lease, trade, or otherwise transfer the Courseware in any way, shape, or form without the express written consent of the SANS Institute.

If any provision of this CLA is declared unenforceable in any jurisdiction, then such provision shall be deemed to be severable from this CLA and shall not affect the remainder thereof. An amendment or addendum to this CLA may accompany this courseware.

SANS acknowledges that any and all software and/or tools, graphics, images, tables, charts or graphs presented in this courseware are the sole property of their respective trademark/registered/copyright owners, including:

AirDrop, AirPort, AirPort Time Capsule, Apple, Apple Remote Desktop, Apple TV, App Nap, Back to My Mac, Boot Camp, Cocoa, FaceTime, FileVault, Finder, FireWire, FireWire logo, iCal, iChat, iLife, iMac, iMessage, iPad, iPad Air, iPad Mini, iPhone, iPhoto, iPod, iPod classic, iPod shuffle, iPod nano, iPod touch, iTunes, iTunes logo, iWork, Keychain, Keynote, Mac, Mac Logo, MacBook, MacBook Air, MacBook Pro, Macintosh, Mac OS, Mac Pro, Numbers, OS X, Pages, Passbook, Retina, Safari, Siri, Spaces, Spotlight, There's an app for that, Time Capsule, Time Machine, Touch ID, Xcode, Xserve, App Store, and iCloud are registered trademarks of Apple Inc.

Governing Law: This Agreement shall be governed by the laws of the State of Maryland, USA.

Table of Contents

Page

Purpose of This Course	05
General Trends	09
Step 1) Reconnaissance	15
- Whois	17
- DNS Interrogation	23
- Website Searches	28
- Search Engines as Recon Tools	34
- Maltego	45
- Web-based Reconnaissance and Attack Tools	49
Step 2) Scanning	52
- Wardialing with Warvox	54
- War Driving	59



This table of contents can be used for future reference.

Note that we put the labs in boldface so you can more easily find them if you need to refer to them during the Hacker Workshop on Day 6.

Course Roadmap

- Incident Handling
- Applied Incident Handling
- **Attack Trends**
- Step 1: Reconnaissance
- Step 2: Scanning
- Step 3: Exploitation
 - Gaining Access
 - Web App Attacks
 - Denial of Service
- Step 4: Keeping Access
- Step 5: Covering Tracks
- Conclusions

Attack Trends

1. Motivation
2. Caveats and Getting Permission
3. The Underground Hacking Community and Hacktivism
4. Attacks for Fun and Profit
5. Software Distribution Site Attacks
6. Hacking with Kinetic Impact
7. The Golden Age of Hacking

These five steps represent the flow of an attack, from initial information gathering to "you are owned" to covering tracks. Although particular scenarios may deviate slightly from this routine or expand upon it, these essential steps are used in many attacks. An attack starts with reconnaissance (step 1), whereby an attacker conducts an open-source investigation to gain information about a target. Step 2 is scanning. An attacker uses a variety of mechanisms to survey a target to find holes in the target's defenses.

Step 3 involves exploiting systems. In this phase, an attacker tries to gain access, undermine an application, or deny access to other users. In step 4, the attacker maintains access by manipulating the software installed on the system to achieve backdoor access. Finally, in step 5, the attackers maintain their hard-fought access by covering their tracks. They use a variety of techniques to hide from users and system administrators. After we discuss this overall attack process, we address how attackers put these pieces together in a variety of sample attacks. We end with conclusions. So, what is the purpose of this course? Why are we here? I'm glad you asked....

Why We're Covering What We're Covering

- Why we chose these tools and techniques
 - They are in widespread use right now
 - Based on the collective experiences at the SANS Internet Storm Center, incident-response activities in large and medium enterprises and input from hundreds of incident handlers
 - They provide us fundamental information about the principles the attackers employ
 - They illustrate what we need to do to defend ourselves
 - Some of them are pretty darn nifty (although nasty)

SANS

SEC504 | Hacker Tools, Techniques, Exploits, & Incident Handling 6

Over the next several days, we cover approximately 100 tools and techniques. We select these particular attacks because they are the most damaging and widely used today. In addition, each attack illustrates what we need to do to defend our systems. For example, there are dozens of sniffing tools in widespread use. However, by covering tcpdump, Wireshark, and Dsniff, we can get an excellent feel for the nastiest of attacks and how to stop them.

In addition, never underestimate your adversaries! You need to understand their tactics and be ready to defend your network.

Always Get Permission

- Full and documented permission is essential before you run any of these tools on a network
- When getting permission, it needs to be in writing
 - Verbal agreements don't hold up to well in court
- The documented permission should also state that the giver of permission understands there may be "adverse" side-effects of the scanning or testing activity
- This is also known as a "Get Out of Jail Free" document
- Get written permission! Sample form at:
http://www.counterhack.net/permission_memo.html

It is often the case where testing is done without proper permission. Often, people believe that if they are testing a "friend's" network or a network for a company they work for, they will be fine. However, we would caution anyone attempting to do any testing at all to always get documented permission. A verbal is never good enough.

Remember, if something goes wrong, often people try to find someone to blame. Unfortunately, it is very easy to target the person who ran the test.

Always get permission from the appropriate authorities in your company before using any computer attack tools to locate vulnerabilities. You can find a sample form for getting such permission at http://www.counterhack.net/permission_memo.html. Have your lawyers look it over and tweak it to fit your needs. Please note that this form is suitable for an employee doing a test of his or her employer. It is NOT suitable for a third-party penetration testing company, as it does not include limitation of liability language required for such contractual relationships.

General Trends

- Excellent communication through the computer underground
 - Chat, web, informal grouping, and hacker conferences
- Rise of hacktivism
 - Hacking to make a political point
 - Not just website tampering
 - Manipulating the computer and financial infrastructure of a target for political reasons is also a form of hacktivism
 - Allowing political dissidents to communicate without interference from oppressive governments
- Ransomware

The computer underground has a highly effective means of sharing information. We need to keep up by sharing information.

Hacktivism, which is launching computer attacks to make a political point, has been increasing. The most obvious form of hacktivism is website tampering. However, don't think that website tampering is the only form of hacktivism. Other elements of hacktivism include setting up anonymous remailers so people can communicate without being observed by oppressive governments. In addition, manipulating the financial infrastructure of a target organization for political reasons is an extreme form of hacktivism.

We are also seeing a large explosion of Ransomware, this is where the bad guys take over a system and somehow blackmail the victim. This can be done either by encrypting the victim hard drive or some other devious ploy, like dumping the users' private emails.

General Trends – Software Distro Site Attacks

- Hack into web and file-sharing sites and alter software to include backdoor
- Everyone who downloads and uses the tool is impacted
 - Numerous historical examples
- Another approach is embodied in ISR-Evilgrade tool
 - Listens for software to request update
 - Sends response with malware
 - Currently includes modules for Java browser plug-ins, Winzip, WinAmp, MacOS X, OpenOffice, iTunes, LinkedIn toolbar, and more
 - More than 60 software packages in total whose Internet updates can be subverted this way

A disturbing attack vector involves an attacker placing a Trojan Horse backdoor version of a commonly used software tool on the web or FTP server used to distribute that tool. There are numerous examples over the past decade of such attacks.

A related attack vector involves undermining the automatic update process used by some software. The ISR Evilgrade tool implements this attack by listening for requests for software upgrades and injecting malware as the response. Currently, Evilgrade can undermine the update process for the Java plug-in for various browsers, WinZip, WinAmp, Mac OS X, OpenOffice, iTunes, and more.

Unfortunately, this tool has not been updated since 2010. Even more disappointing is the fact that it still works on many of these products.

General Trends – The Golden Age

- The marriage of general attack tools and worms, viruses, and bots is resulting in powerful techniques
 - Worms are increasingly being used to carry bots, backdoors, password crackers, and scanners
 - Botnets are growing large with self-replicating code
 - Several active botnets with more than 1 million hosts
- Attacks from multiple sources simultaneously
 - Distributed, cooperative attacks are all the rage
 - Using groups of coordinating attackers or a single attacker with a botnet
- Bottom line: It's a good time to be an attacker (or a security practitioner)

As computer systems and networks advance, the analogies to biological systems greatly increase. As we move forward, the linking of worms and virus-distribution methods to attack tools is growing. Distributed Denial of Service tools, sniffers, scanners, and backdoors, are spread using worm techniques. All of these are being bundled into bots, which are remote-control tools that are used by attackers to control a vast number of systems. We've seen some botnets grow to well over a million compromised hosts!

Many of these techniques are merged and used in conjunction with each other, blurring defined lines of rootkits, malware, virus and adware.

The bottom line here is that we live in the Golden Age of Hacking. But, it's also the Golden Age of Information Security. The two go hand-in-hand.

Reconnaissance

- Reconnaissance is "casing the joint"
- Two general types of attackers
 - **Script kiddies:** Look for low-hanging fruit, and may skip this step
 - **Attackers out to get a particular site:** This step is extremely important
- Helpful step for experienced attackers

Detailed reconnaissance helps an attacker get a feel for your network before ever firing a packet in anger. The Internet itself is a treasure trove of information for a curious attacker.

To begin an attack, your adversaries gather as much information as possible from open sources. Think about attacks in the plain-old real world for a minute. (I know it's hard to think about non-virtual things... but occasionally, we must.) Before bandits rob a bank, they visit the particular branch, look at the times that the security guards enter and leave, and observe the location of security cameras. In addition, they may even use white pages to find the address of the bank and a map of the city to plan their get-away path. This is the same first step in cyberattacks.

- When registering a domain name, the registrar requests
 - Postal addresses
 - Phone numbers
 - Names of points of contact
 - Authoritative domain name servers
- This information can be used in an attack
 - Social engineering, war dialing, war driving, scanning

Attackers rifle through domain name information for useful tidbits in attacking a target. Every time you register a domain name (such as sans.org), you provide detailed contact information about your organization, including the name, postal address, phone number, and e-mail address for your technical, billing, and administrative contact. In addition, your registration information includes the IP addresses of your authoritative domain name servers.

All this information can be used to attack your organization. A bad guy could use this registration information as follows:

- **Contact names:** Social engineering, duping users via the telephone into giving up useful information
- **Telephone numbers:** War dialing, finding unsecure modems to infiltrate an internal network
- **Postal addresses:** War driving, finding unsecure wireless access points to attack
- **IP addresses:** Scanning, looking for openings in the target

- Attackers look for IP address assignments in these geographic whois databases:
 - ARIN (American Registry for Internet Numbers)
 - www.arin.net
 - RIPE NCC (Réseaux IP Européens Network Coordination Centre)
 - www.ripe.net
 - APNIC (Asia Pacific Network Information Centre)
 - www.apnic.net
 - LACNIC (Latin American and Caribbean NIC)
 - <http://lacnic.net>
 - AFRINIC (Africa's NIC)
 - www.afrinic.net
 - DoDNIC (Department of Defense NIC)
 - <http://www.nic.mil> (requires account and certificate)
- Another useful site to check out for Whois information
 - www.uwhois.com with over 196 countries

In addition to getting the registration information (name, phone number, e-mail address for various contacts and DNS information), an attacker may also want to see if any IP address blocks are assigned to the target. If the target organization has been allocated a block of addresses, the attacker can discover the assignment by using the whois databases maintained by ARIN, RIPE NCC, APNIC, LACNIC, and DoDNIC. The last one of these, used by the U.S. Military, requires an account and a client-side certificate to access.

Many organizations don't have their own IP address allocation. Instead, they get addresses from their ISPs. In such cases, ARIN, RIPE NCC, APNIC, LACNIC, AFRINIC, and DoDNIC reveal little information about the target.

Another useful source of whois information is uwhois.com. It supports domain name registration lookups for more than 196 countries.

- Preparation
 - Just live with it: That's just the way the Internet is
 - Use organization name or title with real e-mail and phone number
 - Be CAREFUL with this! Make sure a real, live, responsive human answers
 - Keep records up to date
 - Be wary of anonymous registration agents
 - Network Solutions and Go Daddy offer private registrations for an extra U.S. \$9.99 per year
 - <https://www.networksolutions.com/domain-name-registration/private.jsp>
 - <http://www.godaddy.com/domainaddon/private-registration.aspx>
 - Incident handlers depend on being able to use whois info to contact each other
- Identification:
 - You can't actually tell someone has looked you up
- Cont, Erad, Recov: N/A

How do you defend against this style of reconnaissance? Most organizations just live with it, accepting that detailed information loaded in whois databases is part of Internet life. Others choose to replace particular people's names with an organization name in their registration records. This procedure may limit the value of the information to a social engineer. However, make sure that you use a real organization name where someone responds to any requests that come in from the people using whois database information.

If you use a fake name or an unresponsive organization number in your registration data, no one can contact you in the event of an emergency. If your site starts attacking mine, I contact you through your whois entry information. If that data is out of date or bogus, we cannot coordinate and stop the attackers.

Also, be wary of anonymous registration agents. These companies allow you to register through them, and enter their contact info into a whois database instead of your own contact data. Network Solutions and Go Daddy offer such a service for an additional US \$9.99 per year plus the registration fee itself. Incident handlers depend on being able to use whois info to contact each other quickly. If you go through a registration agent that doesn't reveal your information, you slow down how quickly other incident handlers can reach you. That gives bad guys more time to attack us, sadly.

- The Domain Name System is full of useful information about a target
- The attacker's goal is to discover as many IP addresses associated with the target domain as possible
- The nslookup command can be used to interact with a DNS server to get this data
 - Included in modern versions of Windows
 - Included in most UNIX implementations
 - Deprecated in some UNIXes and limited on some Linux variants
- Dig is another useful tool for DNS recon

Nslookup is a program that can be used to interrogate DNS servers.

The nslookup command works in both modern Windows systems and UNIX. However, in UNIX, nslookup is being deprecated. If you run it, it may bark at you, telling you to use dig or host. In the latest versions of Linux nslookup, the command has been stripped so that it cannot perform zone transfers, which is a useful technique for getting a lot of information about a target domain. If your Linux nslookup gives you an error message saying that zone transfers aren't supported, use dig on Linux.

- On some UNIX variations, nslookup can be used for zone transfers
 - Using the same technique used for Windows on previous slide
- Other nslookup variations (including the one for recent versions of Linux) do not support zone transfer
- Use dig instead

```
$ dig @[DNS_server_IP] [target_domain] -t AXFR
```

On some versions of UNIX, you can use nslookup with the same syntax as Windows to do a zone transfer, just like we saw on the previous slide.

However, on recent versions of Linux, nslookup cannot do a zone transfer. Instead, we can use dig to achieve the same goal. To run a zone transfer using dig, type the following at the command prompt:

```
$ dig @[DNS_server_IP] [target_domain] -t AXFR
```

Course Roadmap

- Incident Handling
- Applied Incident Handling
- Attack Trends
- **Step 1: Reconnaissance**
- Step 2: Scanning
- Step 3: Exploitation
 - Gaining Access
 - Web App Attacks
 - Denial of Service
- Step 4: Keeping Access
- Step 5: Covering Tracks
- Conclusions

Reconnaissance

1. Overview
2. Whois Lookups
3. DNS Interrogation
4. **Website Searches**
5. Search Engines as Recon Tools
6. Maltego Recon Suite
7. Web-Based Recon and Attack Sites

After getting information from whois databases and DNS servers, attackers also interrogate your own web servers.

Other Open-Source Information

Website Searches

- Public databases
 - SEC's Edgar database for publicly traded U.S. companies
 - <http://www.sec.gov/edgar.shtml>
 - Job sites (such as monster.com)
 - www.pipl.com and <https://connect.data.com>
 - www.namechk.com
 - Hacker sites
- Other open-source information
 - Newspapers blogs, and magazines
 - Social networking sites (what expertise, which friends/associates)
 - Facebook, Twitter, Orkut, LinkedIn
 - What are people sharing about your organization
 - Newsgroups with postings from employees



facebook

twitter

SANS

SEC504 | Hacker Tools, Techniques, Exploits, & Incident Handling 30

Job-site databases can be particularly interesting. If a company is looking to hire a Checkpoint FireWall-1 administrator, what type of firewall do you think it has?

In addition, various other open-source information is available. Newspapers, magazines, blogs, social-networking sites, newsgroups, and other sites could provide just the information required by an attacker to launch a more focused attack against your organization.

We can also use sites such as namechk to identify which social-networking sites a target user account may be using. Currently, namechk checks more than 100 social-networking sites to see if a given account is in use. This can be used by an attacker to develop Social Engineering (SE) pretexts. For example, if a target user receives an e-mail stating his account with last.fm is about to expire, he is far more likely to click the link if he actually has an account with that site or service.

This can also be helpful for an attacker to identify which users are more susceptible to SE attacks. Generally speaking, users who are more active online are easier targets because they have a greater predisposition toward clicking links and interacting with strangers.

Pushpin Output

Website Searches



The second pushpin output is a full listing of each social-media post. If you hover over any one of the posts, it shows you where on the map that particular post was made.

This has been used in numerous assessments to discover access points and even people bringing their phones into secure (and sometimes even classified) areas, such as military bases.

Note the one post that was redacted above. This post originated from Apple headquarters and was a full Windows 7 product key.

The best way to use this tool is to regularly run it for your sensitive locations. Always be on the lookout for users who frequently post social-media posts and pictures from work. These people tend to be easy targets because they regularly interact with numerous people online (many of whom they don't know personally).

Course Roadmap

- Incident Handling
- Applied Incident Handling
- Attack Trends
- **Step 1: Reconnaissance**
- Step 2: Scanning
- Step 3: Exploitation
 - Gaining Access
 - Web App Attacks
 - Denial of Service
- Step 4: Keeping Access
- Step 5: Covering Tracks
- Conclusions

Reconnaissance

1. Overview
2. Whois Lookups
3. DNS Interrogation
4. Website Searches
5. **Search Engines as Recon Tools**
6. Maltego Recon Suite
7. Web-Based Recon and Attack Sites

Beyond trawling the web generally, attackers are increasingly utilizing the single most popular source of info on and about the web: Google. Let's see how.

Google Maps for Planning Physical Access for Computer Attacks

- Check out maps.google.com for satellite imagery
 - Sometimes used by attackers planning physical attacks, or coordinating physical and computer attacks
- Google Street View shows even more detail
 - Available for some geographic locations, but not everywhere
- This map API can be used with multiple third-party applications



Google added satellite imagery maps, accessible via maps.google.com. Look up an address, and click the Satellite link. You have a scrollable and zoomable photographic image of the area you just mapped. It's useful and a bit scary. Some attackers use these features when planning physical attacks against a target organization, scoping out roads, walkways, and doors associated with target buildings.

For even more detail, Google supports its Street View option for some geographic locations, showing a view of a person on a street, with the ability to pivot, turning around to see detail in a 360-degree radius.

Later, we see how the Google Maps API can be used to tie together data from multiple sources to give a great physical view of a specific location.

Additional Search Tips and Types

- Surround literals with " ", as in "Soc Sec Num"
- Add minus (-) to a search term to maximize effectiveness of resulting hits
 - Excludes pages with a given word
 - For example, search on: site:sans.org (www.sans.org)
- Search for airline status
 - Type in airline and flight number
 - Front end for Travelocity
- Search for VIN for vehicle information
- Search for UPC number for product info

Search Engine Recon

bing United Airlines 3614

Flight status for United 3614
flightstats.com · 2 minutes ago

Arriving late at 1:29 PM in DEN
Track this flight in real time

FROM	AUS Austin	12:07 PM (was 12:08 PM) 10/07/2013
TO	DEN Denver	1:29 PM (was 1:21 PM) 10/07/2013

Other flight segments: ALB-ORD · Operated as: G73614

Google Web Images Groups News Finance

075596076924

Web Results 1 - 8 of 8 for 075596076924 (0.14 seconds)

Tip: Try Google Answers for help from expert researchers

Link up UPC number 0 76596 07692 4
www.usccadatabase.com

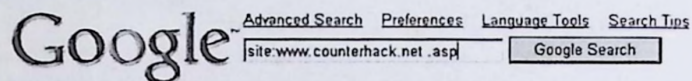
In addition to the search directives listed on the previous page, keep these other useful features in mind.

First, you can search for a literal string using double quotes. For example, to search for the phrase social-security number, with those exact words in that exact order, search for "social security number." However, remember that Google is always case insensitive, even with the double quotes.

In addition, you can add "-" before a word in a search to find results that do not include that given word. This is immensely helpful in narrowing down a search and maximizing the value of the 1,000 results that Google will give you. For example, you could search for site:sans.org -www.sans.org to find domain names of systems associated with sans.org other than www.sans.org. It shows you some other machines associated with SANS.

Finally, some cute and useful search possibilities include looking up an airline and flight number. Google responds with the current status of the flight and its location in the air! Also, searching for VIN shows motor-vehicle information, and a UPC number shows product information. That can be helpful research! In essence, Google is acting as a front-end search engine for Travelocity (and fboweb) for flight tracking, CarFax (for VINs), and UPCCDatabase.com (for product info).

- Search for specific file types on a target domain
- Look for active content: .asp, .jsp, .php, .bak or .cgi
- Excel spreadsheets: Search for .xls and view it as HTML...
 - Spreadsheet image comes from Google cache
- .ppt can also be useful
- For example, search for
 - site:www.[target].com asp
- “filetype:” is useful, but also try just the suffix
- “filetype:” is the same as “ext:”



We've seen how to search for links, info, and cached information, all associated with a specific site. But, for what will the attackers actually search? Here's where search engine recon shines.

Whenever I do search-engine reconnaissance, I use the “site:” directive and look for the following file types:

- asp, jsp, php, cgi, and others: These types of files indicate active web content and may be vulnerable
- xls and ppt: Organizations sometimes don't even realize that they've left an Excel spreadsheet or PowerPoint presentation on their website
- Other miscellaneous file types suited to that target

For example, to search the site www.counterhack.net for Active Server Pages, an attacker could perform a Google search on site:www.counterhack.net asp.

Note that I do not use the “filetype:” directive in my searches, although Google supports it in finding doc, pdf, ps, xls, rtf, txt, ppt files, and countless other file types. I find that, sometimes, Google doesn't properly categorize a file. That's why I use the suffix (doc, pdf, ps, xls, rtf, txt, ppt, and more) as a search directive. Then, after searching for the suffix as a search term, I usually also do a “filetype:” search. It works far better for me to do both kinds of searches (for the suffix as a search term and for the suffix as part of the filetype: directive). Note that the filetype directive is synonymous with the ext directive. They do exactly the same thing.

This is also why it is important to use different search engines. For example, some search engines won't allow you to search for the @ as part of an e-mail search. Rather, they simply replace the @ with a wildcard. However, other search engines, such as Baidu, allow it.

Note that this is more of an art than a science. Search-engine providers are constantly tweaking the way they handle searches and provide results.

- We can perform various searches associated with commonly exploited systems
 - Available remote desktop systems: `ext:rdp rdp`
 - Default web material (Apache, IIS, ColdFusion, and others)
 - "Test Page for the Apache Web Server"
 - "Welcome to Windows 2000 Internet Services"
 - Web-based FileMaker Pro databases: "Select a database to view"
 - Make sure to use quotes
 - Indexable directories: `intitle:index.of "parent directory"`
 - User IDs and passwords (look for "password" and "userid")
 - Shell history (look for common shell names and commands)
 - Video cameras (example: search for `inurl:"ViewerFrame?Mode="`)
- FOCA has the ability to identify many of these vulnerabilities

An attacker can also do searches for potentially vulnerable systems directly. One of the most startling is doing this search: `ext:rdp rdp`. This turns up systems that can be remotely managed via Windows Remote Desktop Protocol. Also, if I search for text from the default Apache install and your site appears, I know that you are likely running the Apache web server. The same logic applies to IIS. Likewise, I might be able to determine that you built your website using ColdFusion or another development platform by looking for text associated with default material on those platforms.

Searches can help find HTTP-accessible File Maker Pro databases. By searching for "Select a database to view," an attacker gets a list of Internet-accessible databases. Although some are password protected, many aren't. Indexable directories that someone has left on a website are also useful and can be discovered by searching for: `intitle:index.of "parent directory."`

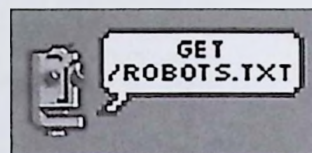
Attackers can also look for command shell history and even hidden hyperlinks and indexes that aren't easily accessible by humans. The attackers just let Google bot work its magic. This technique for finding vulnerable systems has become so widely used that, starting in December 2004 with Santy, worms use Google to locate vulnerable systems and spread. Santy searched Google for a vulnerable version of the phpBB script and then attacked systems running it. Because of this, Google is now filtering some of the common PHP and related searches conducted by worms. Still, new searches for vulnerable systems are discovered all the time.

Another set of fascinating searches involves finding web-accessible video cameras. The search `inurl:"ViewerFrame?Mode="` shows numerous Panasonic cameras around the world, some of which allow you to control zoom, tilt, and pan. Likewise, numerous other searches find other types of cameras and their associated web controls.

Search Engine Recon Defenses

Search Engine Recon

- Look for information leakage using Google yourself
- Instructions at Googles Web Master Tools
 - Remove the website (robots.txt file)
 - robots.txt is NOT a security feature; it must be world readable for the search engine crawlers to find it
 - It draws attention to files, and careful attackers are wise to plunder it for possibly interesting directories and files on a target website
 - Interesting place to refer to a honeypot web page, only referred to in robots.txt
 - Monitor all IP addresses that try to access page
 - Remove individual pages ("NOINDEX, NOFOLLOW" meta tag)
 - Remove snippets ("NOSNIPPET" meta tag)
 - Remove cached pages ("NOARCHIVE" meta tag)
 - Remove an image from Google's Image Search
- Remove unwanted items from Google
 - URL re-crawl request form at Goolge Webmaster tools
 - See <http://www.robotstxt.org> for info about non-Google crawlers



To defend against these cyber reconnaissance raids, check your own environment to see what information you are leaking. Check out what information you have publicly available on your own websites and think about what an attacker could do with that data. Use the Google tips we discussed on the previous slides for searches.

Also, if you find that Google has indexed a URL or cached a page that you didn't want it to, you can use the URL re-crawl request submission form at Googles Web Master Tools. This removes the page the next time the Google bot crawls your website, which likely occurs within the next 24 hours.

You cannot just submit a URL to remove. If that were the case, someone could actually have you removed from Google without your knowing it! To get Google to remove you, you have to not only fill out the form, supplying it with your URL. You also have to alter the page on your own website, using a robots.txt file or a meta tag, to indicate that you want it removed. That way, when you fill out the form saying you want a page removed, Google automatically goes to that page to see if it has been altered to include the robot.txt file or removal meta tag. So, you have to coordinate with your website administrator to have pages removed from Google.

- Paterva's Maltego is an intelligence-gathering tool that searches through various public information sources
 - Gathers information about relationships between
 - People, social networks, companies, websites, domains, IP addresses, and more
 - Based on the concept of "transforms"
 - Converts one piece of information into another
 - Graphically displays relationships of information
 - Cascading hierarchies of data points mapping to other data points
 - Runs on Linux, Windows, and Mac OS X
- Available in two forms at <http://www.paterva.com/web6/products/maltego.php>
 - Commercial edition: Approximately US \$760 per year
 - Community edition: Free, but with some limitations:
 - Nag screen for 15 seconds
 - Cannot save or export results
 - Zoom levels are limited
 - Only 75 transforms per day
 - Run transforms on only one entity at a time



The Maltego tool was released by a company named Paterva. This intelligence-gathering tool provides a wealth of information for researchers, investigators, and computer attackers conducting detailed reconnaissance. Maltego allows a user to start with one or more pieces of information, such as a person's name, phone number, domain name, e-mail address, website URL, IP address, and so on. Given that piece of information, Maltego applies the concepts of transforms, a series of lookups into public sources of information to find related pieces of information. Transforms convert one piece of information (such as a domain name) to another piece of information (such as an IP address). Many dozen transforms are included in Maltego.

The result, when many transforms are applied repeatedly, is a cascading hierarchy of related information all associated in some way with the original data.

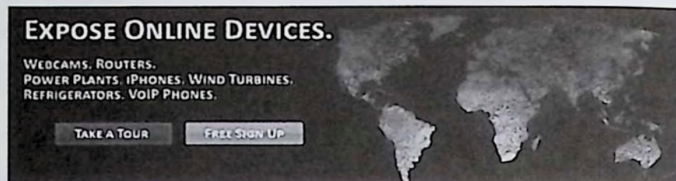
Maltego runs on Linux, Windows, and Mac OS X, and is available in two forms: a commercial edition for approximately US \$760 per year, and a free Community Edition that has some limitations. The Community Edition allows for some powerful reconnaissance activities, but it includes a nag screen for 15 seconds asking you to purchase it every time it is launched. It also prevents saving or exporting results, limits the level of depth you can zoom to in the hierarchical display, and only allows 75 transforms to be applied per day. Also, you can only run transforms on one entity at a time, instead of being able to launch simultaneous look-ups on multiple pieces of data on the display.

- **Preparation**
 - Ensure that publicly available information about your organization is accurate
 - Keep records up-to-date
 - Conduct your own recon
 - Check to see what is available about your organization and your important personnel
 - Request that inaccurate or damaging information be removed from sources
 - May be politically difficult or impossible to compel removal of some information
- Ident, Cont, Erad, Recov: N/A

To defend against Maltego, make sure that information about your organization in various public sources is accurate by keeping your whois and domain information up to date. You should also conduct reconnaissance about your own organization, with appropriate permission, to see whether the information available is accurate. If you find information that is inaccurate or damaging, you may want to work with your lawyers to formulate requests to have it updated or removed. Depending on the nature of the information, and the particular publicly available database in which it is located, you may or may not be able to compel someone to purge the data.

Web-Based Recon/Attack Tools

- Numerous websites offer the capability to research or even attack other sites
- Links to Internet Scanning Web Pages (Traceroute, ping, port scans, Denial of Service tests)
 - Shodan at www.shodan.io
 - www.dnsstuff.com
 - www.tracert.org
 - www.network-tools.com
 - www.securityspace.com (commercial with free trial)



These websites include forms that allow you to enter a target site and do research, or, in some cases, even attacks. These websites can perform DNS lookups, reverse lookups, traceroutes, and a variety of other valuable services. From a test machine on a separate network from your production system (such as a dial-up account), these tools can be interesting to experiment with.

Course Roadmap

- Incident Handling
- Applied Incident Handling
- Attack Trends
- Step 1: Reconnaissance
- **Step 2: Scanning**
- Step 3: Exploitation
 - Gaining Access
 - Web App Attacks
 - Denial of Service
- Step 4: Keeping Access
- Step 5: Covering Tracks
- Conclusions

Scanning

1. **War Dialing**
2. War Driving
 - Lab: Wireless LAN Discovery with InSSIDer
3. Network Mapping with Nmap
4. Port Scanning with Nmap
 - Lab: Nmap
5. Evading IDS/IPS
6. Vuln Scanning with Nessus
 - Lab: Nessus
7. SMB Sessions
 - Lab: SMB Sessions

After completing thorough reconnaissance of the target, attackers begin scans to find openings in the target system.

Let's start by discussing war dialing: an older technique, but still amazingly successful.

Even today, an unprotected modem provides the easiest method for penetrating a network. Whenever we perform a war dialing assessment, more often than not, we get into the target network.

- HD Moore released a war-dialing tool called WarVOX
- Free at <https://github.com/rapid7/warvox>
- Conducts war dialing using one or more VoIP accounts
 - No telephony hardware required ... just an Internet connection and VoIP account
 - Provider must support IAX protocol
 - Several compatible VoIP providers that do not prohibit war dialing are listed on the WarVOX website
 - Traditional modem-based war dialing: 1,000 numbers in approx. 8 hours
 - WarVOX war dialing: 1,000 numbers per hour
- A significant increase in speed
- Supports caller ID spoofing
 - Enter a single number for all calls dialed
 - Enter variable number of Xs for pseudo-random source number
 - Enter "SELF" to make caller ID same as dialed number; may bypass PIN authentication in some voicemail systems

HD Moore released a tool called WarVOX that focuses on conducting war dialing assessments of target telephone number ranges. Unlike traditional war dialers that use a modem to dial phone numbers, WarVOX relies on VoIP communications. A user configures WarVOX with account information from a VoIP service provider, and WarVOX uses that account to dial a list or range of provided phone numbers. No telephone line or modem is required by WarVOX. Instead, just a broadband Internet connection and one or more VoIP accounts suffice. The VoIP service provider must support the Inter-Asterisk eXchange (IAX) protocol for VoIP. The WarVOX website includes a handy list of different VoIP service providers that are compatible with WarVOX and that do not explicitly prohibit war dialing using their service.

The real benefits of WarVOX are increased speed and flexibility. A traditional modem-based war dialer, such as THC-Scan, can complete about 1,000 phone calls in an 8-hour span. WarVOX, on the other hand, can typically dial more than 1,000 numbers per hour, provided that it is connected with a typical residential broadband Internet connection, and the VoIP provider supports multiple calls simultaneously from one account, which most do.

Besides the increase in speed, the flexibility provided by WarVOX includes caller ID spoofing, where it provides three options: The user can configure it with a single number to use as the caller ID value for all numbers dialed; or, the user can specify a number, such as 1 555 555 XXXX, where each X will be replaced with a pseudo-random digit between 0 and 9 for each number called; finally, WarVOX can be configured with "SELF" as the caller ID value, which makes it set the caller ID value to the same number that it is dialing. This option can be used to bypass PIN authentication in some voicemail systems.

Get it at <https://github.com/rapid7/warvox>.

- So, I've found a bunch of modems or phones ... what do I do now?
- Focus on out-of-band router access and phones
- Review the war dialer logs and look for familiar login prompts, warning banners or phones with no passwords
- Connect to each discovered modem
 - Oftentimes, you find a router or a phone without a password
 - If there is a user ID/password prompt, guess
 - Make it an educated guess, based on the system
 - What are default accounts/passwords
 - What common things are associated with the target

Many systems tell you what platform they are (for example, "Hi, I'm BSD!"). For others, you can determine this information from the nature of the prompt. UNIX boxes and Cisco router prompts are particularly easy to identify. Also, phones without password PINs are also great targets.

Although guessing passwords is a time-consuming process, keep in mind that time is the single greatest resource your adversaries have.

For password guessing, a complete list would take up numerous pages, indexed by system type. This partial list can get you started (try each for userID and password, and all combinations):

- root
- sync
- bin
- nobody
- operator
- manager
- admin
- administrator
- system
- days of the week
- COMPANY_NAME
- COMPANY_PRODUCT

- **Identification**
 - Activate scanning-detection functionality in your PBX, if available
 - Consider "PBX Firewall/IPS," such as SecureLogix Voice IPS
 - Monitors trunk connecting PBX to phone network, looking for fax tones
- **Containment**
 - Shut off modems when they are discovered (if they are not needed)
 - Know whom to call in your own telecom group and at the phone company to geographically isolate a modem
- **Erad, Recov**
 - Remove modems from network out-of-band devices (if possible)
 - If modem is absolutely required, change phone number and secure it with strong authentication (token, crypto, or others)

For containment, eradication, and recovery, removing the victim modem is a reasonable idea. If it is absolutely required, move it to another phone number and add stronger authentication, such as a time-based token, smart card, or another technology.

- Many wireless access points (base stations) are configured with no security
 - Blank or default SSIDs are common
- By default, most access points broadcast beacon packets with their SSIDs 10 times per second
- Even for those APs configured not to include the SSID in beacons (SSID cloaking), SSIDs are still sent in clear text whenever anyone uses the wireless LAN
 - Therefore, the SSID is, in no way, a security feature
- Various wireless security protocols (WEP and LEAP specifically) have significant flaws
 - Just "turning on" security is often not enough protection for sensitive traffic and systems

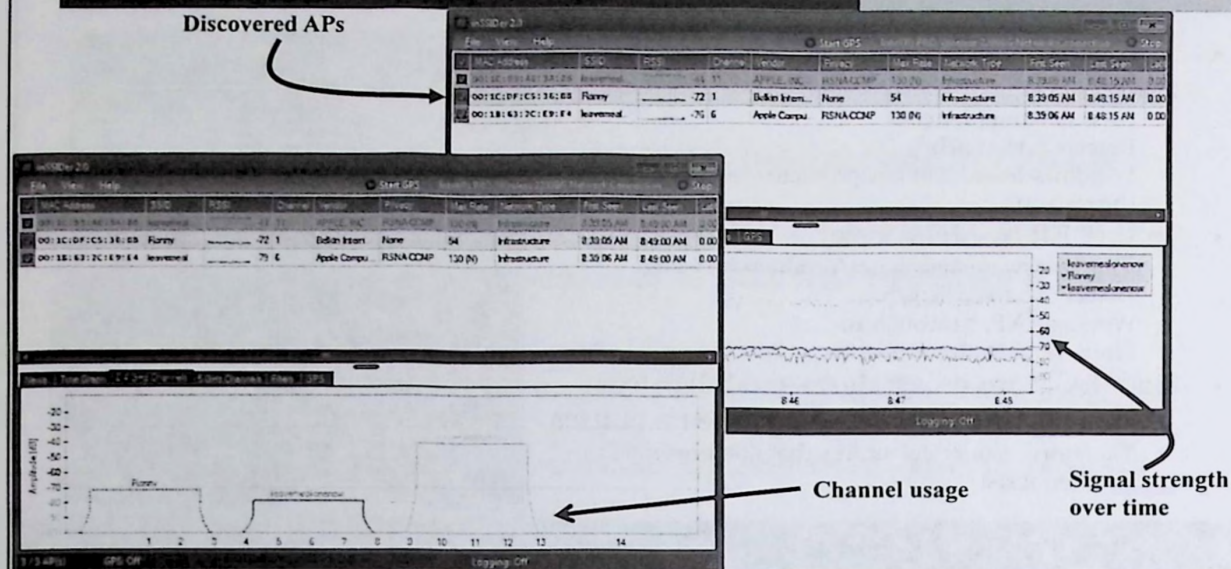
The SSID is the services set identifier. It acts as a name of a wireless LAN. Despite what some people think, SSIDs offer no real security. It is NOT a password.

Most access points include their SSID in beacon packets sent approximately every 100 milliseconds. You can configure most access points to omit their SSIDs from their beacons, which is a feature known as SSID cloaking. This is a small boost to security, however, because access points still send all SSIDs in clear text when authenticated users use the access point. We cover some tools shortly that can gather SSIDs from sniffed traffic even when broadcast beacons are disabled on an AP.

Compounding the problem, various wireless security protocols (WEP and LEAP specifically) also have significant flaws, as we see later. Thus, just "turning on" security is often not enough protection for sensitive traffic and systems.

InSSIDer GUI

War Driving



62

The InSSIDer GUI includes three sections. The upper-most section (a thin grey line at the top of the screen) is associated with control of the wireless interface, with its File, View, and Help menus, along with the Start and Stop toggle button at the top right, which turns on the gathering of wireless information. There is also a button in this bar to start or stop GPS recording. A drop-down menu lets the user choose a wireless interface.

Below the configuration line, we have an inventory of all wireless devices InSSIDer has spotted, including the MAC address, SSID, channel, and type of encryption in use, such as WEP, WPA2 (which InSSIDer displays by the use of two protocols associated with WPA2: RSNA-CCMP, none, and so on).

At the bottom of the screen, our third section shows various tabs we can use to look at how the signal varies over time (Time Graph), a graphical display of channel usage (2.4 GHz or 5 GHz Channels), filters (which can be used to focus on only certain devices given their SSID, MAC address, channel, encryption type, or other properties), and GPS settings.

- Utilize a traditional sniffer, gathering wireless packets
 - Tcpdump, Wire Shark, and more
- Or use a wireless-specific sniffer for better analysis of wireless-specific frame data
 - Omnipcap (formerly Airocap), Commercial
 - <http://www.wildpackets.com>
- Aircrack-ng for cracking WEP and WPA keys
 - <http://www.aircrack-ng.org/>
- ASLEAP by Josh Wright provides a dictionary attack against LEAP authentication

These tools allow an attacker to sniff a wireless network. They grab traffic from the wireless LAN so an attacker can look at the data.

To sniff data from a wireless LAN, you could use Tcpdump or Wire Shark, bound to your wireless card. However, they may not be able to decode all the wireless-specific packets as thoroughly as some of the wireless-specific sniffing tools.

Aircrack-ng is an extremely powerful tool for sniffing and cracking WPA four-way handshakes and launching password attacks on the key.

Josh Wright's tool called ASLEAP provides a dictionary-based attack against the LEAP protocol used in some wireless environments. By attacking the user's Windows password hashes based on sniffed LEAP challenge and response messages, ASLEAP can determine a user's password to gain access through a LEAP-protected WLAN.

- Many people occasionally connect to untrusted WLANS
 - To surf Internet for free
 - "But I just wanted to check my e-mail," he or she may say
- If their machines are hardened, they are safe, right?
- Not so fast ...

A lot of users surreptitiously use wireless LANs. They need Internet access, so they fire up their wireless card and see what's available. They find an open access point and use it to surf the net and synch their e-mail. The legality of such access is determined on a state-by-state basis in the United States.

Given the legal concerns, I'm sure that no one in this class would ever use a wireless access point for Internet access without permission. But, as you know, large numbers of users do.

What's the problem from a security perspective? If their machines are hardened, they are safe, right?

Easy-Creds Attack Stack

War Driving

```
Airbase-NG
07:08:26 Client 88:53:95:34:AE:AD associated (unencrypted) to ESSID: "attwifi"
07:08:33 Client 88:53:95:34:AE:AD reassociated (unencrypted) to ESSID: "attwifi"
07:08:37 Client 88:53:95:34:AE:AD reassociated (unencrypted) to ESSID: "attwifi"
07:08:43 Client B8:E8:56:BB:51:43 associated (unencrypted) to ESSID: "attwifi"

DMESG
Feb 15 07:08:26.000000 wlan: dhcpd: DHCPREQUEST on 10.10.10.103 to 34:ae:53:95:34:ad (Nintendo DS) via eth0
Feb 15 07:08:26.000000 wlan: dhcpd: DHCPREQUEST for 10.10.10.103 from 34:ae:53:95:34:ad (Nintendo DS) via eth0
Feb 15 07:08:26.000000 wlan: dhcpd: DHCPACK on 10.10.10.103 to 34:ae:53:95:34:ad (Nintendo DS) via eth0
Feb 15 07:08:26.000000 wlan: dhcpd: DHCPREQUEST on 10.10.10.103 to 34:ae:53:95:34:ad (Nintendo DS) via eth0
Feb 15 07:08:26.000000 wlan: dhcpd: DHCPREQUEST for 10.10.10.103 from 34:ae:53:95:34:ad (Nintendo DS) via eth0
Feb 15 07:08:26.000000 wlan: dhcpd: DHCPACK on 10.10.10.103 to 34:ae:53:95:34:ad (Nintendo DS) via eth0

SSLStrip

Ettercap - [tunnel]
DHCP: [10.10.10.1] ACK : 10.10.10.103 255.255.255.0 GW 10.10.10.1 DNS 8.8.8.8
DHCP: [64:A3:CB:63:71:12] REQUEST 10.10.10.103
DHCP: [10.10.10.1] ACK : 10.10.10.103 255.255.255.0 GW 10.10.10.1 DNS 8.8.8.8

URL Snarf
TTP/1.1" - - "-" "-"
10.10.10.113 - - [15/Feb/2014:07:10:07 -0700] "GET http://static.ess.app\xe4a.cdn:80/connectivity.tx
t HTTP/1.1" - - "-" "-"
```

68

When Easy-Creds starts, it automatically configures the attacker system to bridge communication between its wireless interface and the Ethernet interface. Remember, the goal is not to just have the victim system connect to the attacker; it is also to allow the traffic to pass through so it can be intercepted. To create the access point, Easy-Creds automatically starts Airbase-NG. In the slide's example, an access point with the ESSID "attwifi" was created. This is one of the more effective ESSIDs because many devices (such as phones) by AT&T wireless automatically joins the nearest access point with this name.

It then logs DMESG messages to track all DHCP leases. In the slide, you can see a Nintendo DS connecting to the evil access point.

If any SSL redirects are encountered, SSL strip intercepts and brokers the SSL/HTTP session so clear-text passwords can be harvested.

Finally, it launches Ettercap and URLSnarf to monitor URLs and launch session hijacking/manipulation attacks.

On Day 3, we go into detail about tools like SSLStrip and Ettercap.

- Once a client joins imposter network, Karmetasploit includes various services
 - **DHCP** (of course)
 - **DNS**: All DNS requests are intercepted, and the attacker's own IP address is returned
 - **POP3**: "I'm your mail server. Authenticate to me."
 - **HTTP**: "I'm also every server on the entire Internet. Want to talk?"
 - **Samba**: All Windows file sharing points back to the attacker's machine

Once the wireless client associates with Karmetasploit, the tool includes a variety of fake services to provide access to the client. First off, it has a DHCP service to provide the client with an IP address. It also includes a DNS server that intercepts all DNS requests (not just those going to the DNS server configured by DHCP) and sends responses of the attacker's choosing. By default, all IP addresses are resolved to the attacker's IP address of the box running Karma.

It includes a POP3 server that pretends to be all POP3 servers on the Internet, accepting and logging passwords sent by the user.

It includes a web server that pretends to be any server on the Internet. Gee, the White House website looks an awful lot like the Gnu website today. Microsoft and Google also look the same. The attacker, of course, can configure specific sites to pretend to be something else, such as a bank or wireless access provider.

Finally, the tool includes a SAMBA server, which pretends to be any file share for which the user is looking.

- MAC address filtering at an access point isn't secure
 - Doesn't scale well and MAC addresses can be spoofed
 - On Linux, you can use the `ifconfig` command to change MAC addresses
`# ifconfig wlan0 hw ether [MACaddr]`
 - On Windows, PowerShell's `Set-NetAdapter` commandlet can do this with a process described at <http://blog.commandlinekungfu.com/2013/06/episode-167-big-mac.html> Many of the tools run on the platforms
- Set SSID so that it doesn't attract attention
- Use WPA2 with a strong password
 - We recommend a password for wireless networks which is at least 21 characters long
 - Length is the most important factor for password strength
 - We will be discussing passwords in Book 4
- Protect client wireless configs!!!

So, how can you defend your network against such attacks?

Do not rely on MAC address filtering at your access point to implement security. Although you could allow only traffic from registered MAC addresses, such security is deeply flawed. MAC addresses can be easily spoofed (either by using the `ifconfig` command in Linux/UNIX or with PowerShell's "Set-NetAdapter" commandlet in Windows). In addition, MAC address filtering doesn't scale well. If you have 100 users constantly buying new wireless cards, it is hard to keep your filters up to date.

To defend your wireless systems, first, set the SSID to a value that doesn't attract attention to your network. Establish a standard for naming wireless LANs in a way that doesn't include your organization's title in the SSID. It's better to name a wireless LAN something like "1234" rather than "bigbank1234." One solution to this dilemma of naming access points is to simply set the SSID to the device's serial number.

Finally, use a strong (meaning long) password with your wireless access points. We recommend a key of at least 21 characters long.

We also recommend protecting your client wireless configs. Attackers can export these configs and easily read the password in clear text. No cracking required.

Defenses – Preparation (3)

War Driving

```
<SSIDConfig>
  <SSID>
    <hex>6968617465636C6F776E73</hex>
    <name>ihateclowns</name>
  </SSID>
</SSIDConfig>
<connectionType>ESS</connectionType>
<connectionMode>auto</connectionMode>
<MSM>
  <security>
    <authEncryption>
      <authentication>WPA2PSK</authentication>
      <encryption>AES</encryption>
      <useOneX>false</useOneX>
    </authEncryption>
    <sharedKey>
      <keyType>passPhrase</keyType>
      <protected>true</protected>

      <keyMaterial>01000000D08C9DDF0115D118C7A00C04FC297EB0100000
09063D9696DFE5E4AA0C342C836A351F900000000020000000000106600000001
000020000000050D777953189B2A47269B3FA567083C13CBEAD8FB026C193499FE
1DAB973730C000000000E80000000020000200000009ADF870661B8E8F932D04C
289F86DDBE03DAECE30FEF604356AF91C969A5893320000000FF5DF63A7AAD516
3DEC30FAC59F671B945BF8BA061FDC8E294CD240678E544434000000073E64129
```

ihateclowns Wireless Network Properties

Connection Security

Security type: WPA2-Personal

Encryption type: AES

Network security: THISISNOTmyHOTSPOTPassword

☒ Show characters

Advanced settings

SANS

SEC504 | Hacker Tools, Techniques, Exploits, & Incident Handling 74

In the screenshot above we have the wireless config for the SSID ihateclowns. This network is using WPA2PSK and as you can see, the keyMaterial is obfuscated.

The screenshot above was taken from a Rubber Duckie attack where a USB HID was used to exfiltrate the key material off a victim system.

The wireless configurations for a system can be exported via the following command:

```
C:\>netsh wlan export profile
```

Once the profile is imported on the attacker's system, they can view the password by simply running the following command:

```
C:\>netsh wlan add profile filename="FILENAME.xml"
```

Course Roadmap

- Incident Handling
- Applied Incident Handling
- Attack Trends
- Step 1: Reconnaissance
- **Step 2: Scanning**
- Step 3: Exploitation
 - Gaining Access
 - Web App Attacks
 - Denial of Service
- Step 4: Keeping Access
- Step 5: Covering Tracks
- Conclusions

Scanning

1. War Dialing
2. War Driving
 - **Lab: Wireless LAN Discovery with InSSIDer**
3. Network Mapping with Nmap
4. Port Scanning with Nmap
 - Lab: Nmap
5. Evading IDS/IPS
6. Vuln Scanning with Nessus
 - Lab: Nessus
7. SMB Sessions
 - Lab: SMB Sessions

This page intentionally left blank.

Lab Conclusion: Go Forth and Find Interesting Access Points

- Let's go out and find interesting access points
 - This can be done around the hotel, your neighborhood, or office
 - This is something we should do on a regular basis at work
- When you return to class, your instructor asks what you found
- Points for access points with fun names and access points without security enabled
- **Please do not connect to any access points without permission**

Let's take some time to go out into the conference, offices, and/or our neighborhoods to find interesting and unsecured access points. The goal of this lab is two-fold.

First, we want you to get familiar with doing this because it is something you should do at work. Second, it can be eye-opening to see just how many unsecured access points there are.

Remember that we are just passively recording the access points around us. At no time are you to connect to any of these access points without permission.

Network Mapping with Nmap

- An attacker wants to understand the topology of the target network
 - Internet connectivity: DMZ, perimeter networks
 - Internal network (with access from modem or wireless access point)
- The layout of routers and hosts can show vulnerabilities
 - Or at least let the attacker know where things are
- Nmap can be used for network mapping and port scanning
 - Written by Fyodor and the Nmap development team
 - Available for Linux and Windows
 - Zenmap GUI lends itself to network mapping and visualization
 - Available for free at www.nmap.org
 - Let's look at network mapping first, and then port scanning

 On the Course USB

SANS

SEC504 | Hacker Tools, Techniques, Exploits, & Incident Handling 00

An attacker wants to understand the topology of your network, mainly Internet connectivity: DMZ, perimeter networks, and your intranet. The layout of routers and hosts can show vulnerabilities or at least let the attacker know where things are.

Nmap, the popular network-analysis tool by Fyodor and the Nmap development team, can be used for network mapping and port scanning, although most people associate it with the latter. We look at using Nmap for network mapping first, and then for port scanning.

Nmap includes a GUI-based front end called Zenmap, which provides excellent network mapping and visualization features.

Sweeping for Network Mapping

Network Mapping

- A common first component of network mapping is to identify the addresses in use by sweeping through address space
 - For example, send an ICMP echo request to a range of IP addresses
 - If something replies, that address is in use by some target system
 - If nothing replies, we assume system not on the network at that address
 - It could be that the firewall is blocking ICMP
- By default, Nmap sweeps each target address before port scanning it
 - This can be reconfigured to use TCP packets or ignored all together (the `-PN` flag in Nmap, formerly `-Po`)
 - By default, to identify which addresses are in use, Nmap sends the following four packets to each address in the target range:
 - ICMP Echo Request
 - TCP SYN to port 443
 - TCP ACK to port 80 (if Nmap is running with UID 0)
 - ICMP Timestamp request
 - When running without UID 0, Nmap sends SYN to port 80 instead of ACK

SANS

SEC504 | Hacker Tools, Techniques, Exploits, & Incident Handling 82

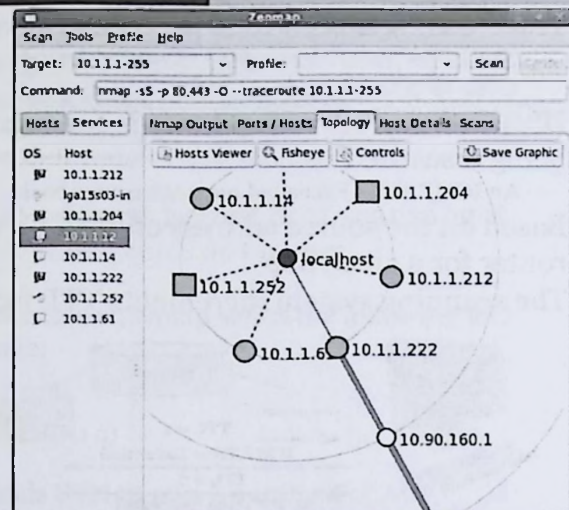
A common initial step in network mapping is to sweep through the target network addresses, sending one or more packets to each address trying to solicit a response. The response indicates that the given address is in use by some target machine.

By default, Nmap sweeps through each target address before it launches a port scan of the address. However, this scanner behavior can be reconfigured so that all addresses are scanned, regardless of whether they are pingable or not. In Nmap, the `-PN` command flag tells Nmap not to ping the target ("no ping"), but to just start the port scan. In older versions of Nmap, this option was `-P0`, but it was changed in more recent versions.

By default, to identify which addresses are in use, Nmap sends the following four packets to each address in the target range: ICMP Echo Request, TCP SYN to port 443, TCP ACK to port 80 (if Nmap is running with UID 0), and an ICMP Timestamp request. If Nmap is not running with UID 0 on a Linux machine, it runs through the same set of four packets, but uses a TCP SYN to port 80 instead of an ACK, because it cannot craft the ACK packet without UID 0. If any of those packets receives a response, Nmap assumes the address is in use by a valid target machine and proceeds to conduct its port scan.

Zenmap Network Map Output

- Output shows topology
 - Cumulative view of recent scans
 - Supports changing focus, zooming, and fisheye view



Once Nmap finishes conducting a network sweep and its tracerouting activities, the Zenmap GUI can provide an interactive graphical portrayal of the network. This output is a cumulative view of recent scans conducted by Nmap, showing each system identified during ping sweeping, along with the series of connections between the systems.

The Zenmap graphical view allows for zooming into targets or specific portions of the network. The user can simply double-click a host to move it to the center of the map. There is also a fisheye view that lets the user have one portion of the network map zoomed in while making other portions of the graph smaller.

On the left-hand side of the display, we can see each host with a graphical depiction of its operating-system type, discovered using the active OS fingerprinting features of Nmap that we discuss later.

- Containment
 - If you notice a particularly frequent ping sweep, you could temporarily block source address
 - Mark such rules as temporary in a comment field, and then purge them on a regular basis (such as monthly)
- Erad, Recov: N/A

If you notice a particularly frequent ping sweep or traceroute coming from a single IP address or network, you could filter that address in your border router or firewall.

If you start blocking source addresses, make sure you regularly examine your filters so they don't become too large and unwieldy. I usually block something for a few weeks or months, and the attackers go away. I can then remove the filter fairly safely.

Port Scanners and the TCP/IP Family

Port Scanning

- Port scanners are a must for any attacker's toolbox
- They help identify openings on a system and the type of system
 - Allow an attacker to focus an attack
- Most Internet applications use TCP or UDP
 - **TCP:** Connection-oriented (for example, sequence preserved and retransmission)
 - **UDP:** Sessionless (for example, datagram; get it there if you can)

TCP	UDP
IP	
Data Link (Ethernet, Token Ring)	

88

To understand port scanners, we first need to do a brief protocol review.

The Internet Protocol (IP) is the common protocol used to move information around the Internet. IP includes the source and destination address of each packet. The Transmission Control Protocol (TCP) and User Datagram Protocol (UDP) ride on top of IP. That is, TCP and UDP messages are plopped inside of an IP message. TCP is session-oriented, in that it applies sequence numbers to messages and tries to deliver them in appropriate order. It also resends dropped messages. UDP makes best-effort delivery, but messages may be dropped or delivered out of order.

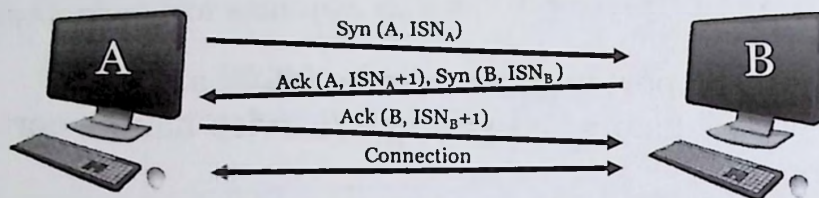
If someone is going to access your system, ports are the entry points or the doors and windows into your system. Therefore, a list of open ports gives an attacker various possible avenues for compromising the system.

Port scanners are a must for any attacker's toolbox. They help identify openings on a system and the type of system and therefore allow an attacker to focus on an attack.

TCP Three-Way Handshake

Port Scanning

- Initial SYN establishes sequence number for A to B
 - Usually, B must remember this, allocating state in its connection queue
- Response SYN-ACK establishes sequence number for B to A



SANS

SEC504 | Hacker Tools, Techniques, Exploits, & Incident Handling 90

All *legitimate* Transmission Control Protocol (TCP) connections (for example, HTTP, telnet, FTP, and so on) are established through this three-way handshake.

The handshake allows for the establishment of sequence numbers (ISN = Initial Sequence Number) between the two systems. These sequence numbers are used so that TCP can provide for reliable packet delivery in sequential order. Sequence numbers are used for sequencing and retransmissions.

Six control bits describe the packet's role in the connection:

- **SYN**: Synchronize
- **ACK**: Acknowledgment
- **FIN**: End a connection
- **RESET**: Tear down a connection
- **URG**: Urgent data is included
- **PUSH**: Data should be pushed through the TCP stack

Note that the control bits can be set independently of one another. For example, you could have a SYN-ACK packet with both bits set.

<i>Source Port</i>	<i>Destination Port</i>
UDP Message Length	UDP Checksum
Data	
.....	

The User Datagram Protocol (UDP) does not have a three-way handshake or sequence numbers and is, therefore, a "stateless" protocol. Retransmissions are handled by the application or are not done at all. UDP is also known as the Unreliable Damn Protocol. It is useful for applications that value speed over reliable delivery, such as voice or video transmissions. Packet sequencing takes up processing overhead, while an occasional dropped packet has minimal impact on a user's perception of voice or video.

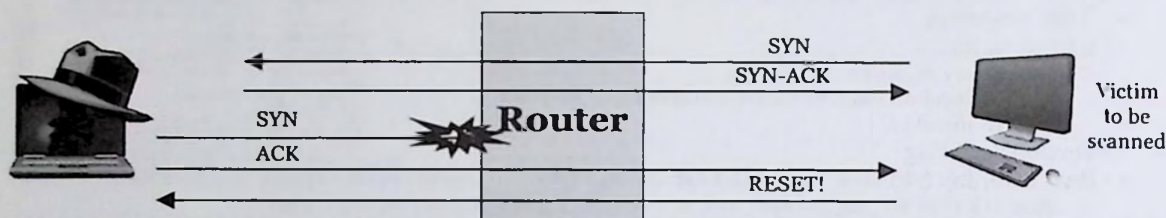
UDP is also used for simple query/response type applications, such as databases or DNS. For such services, I send in one packet and get one response. Therefore, there's no need for sequence numbers for a series of packets.

The UDP packet header is simple. It includes the source port and destination port. No sequence numbers are included.

Nmap – ACK Scanning

Port Scanning

- Suppose you want to allow outgoing connections, but not incoming (network diode)
- You may configure a router to allow in only established connections (for example, connections with ACK control bit set)
 - Allow outgoing SYNs
 - Allow incoming connections only if ACK control bit is set
- This blocks session initiations from the outside
- But an attacker can conduct ACK scan to get past some filters
- ACK scans are useful for mapping, but not for port scanning
- Great for finding sensitive **internal** systems post exploitation



SANS

SEC504 | Hacker Tools, Techniques, Exploits, & Incident Handling 94

A router may allow outgoing SYNs and their incoming responses (for example, established connections with the ACK control bit set), but not incoming SYNs. The reason is that incoming SYNs indicate the beginning of a new session. In this case, the attacker can scan with ACK packets, which the router allows into the network.

A stateful packet filter remembers the outgoing SYNs, so it only allows the incoming packet if it is tied to an earlier outgoing packet. Therefore, an ACK scan does not work through a properly configured stateful packet-filtering device.

ACK scans cannot reliably determine which ports are open or closed, unfortunately for the attackers. Different systems respond in different ways to an unsolicited ACK packet to an open or closed port. In other words, the returned RESET doesn't necessarily indicate that the port is open or closed. However, it DOES indicate that there is a system at the address. So, the ACK scan result can be used to do network mapping instead of a ping sweep. It just cannot be used for a port scan.

This is a great approach for finding internal sensitive systems, such as network management servers, SIM servers, and remote access servers. This technique works because many organizations use simple IP address filtering for segmentation of sensitive LAN segments.

- More than 30 different methods are included in second-generation fingerprinting, including
 - TCP ISN greatest common denominator (GCD)
 - TCP ISN counter rate (ISR)
 - TCP IP ID sequence generation algorithm (TI)
 - ICMP IP ID sequence generation algorithm (II)
 - Shared IP ID sequence boolean (SS)
 - TCP timestamp option algorithm (TS)
 - TCP initial window size (W, W₁ - W₆)
 - IP don't fragment bit (DF)
 - IP initial Time to Live guess (TG)
 - Explicit congestion notification (CC)

The second-generation active OS fingerprinting of Nmap includes more than 30 different tests to determine the operating system type of a target. Included in these tests are measures of the TCP sequence numbers of responses, such as their greatest common denominator and how quickly they change over time. Also, Nmap measures the changes in IP ID values for responses to TCP and ICMP packets. Some operating-system types have different sets of IP ID numbers for TCP versus ICMP, while others do not. (Windows uses the same incremental number for both sets of protocols.)

It also looks at TCP timestamp behavior and TCP window sizes the target system negotiates. Also, Nmap evaluates the behavior of the system to a message with the Don't Fragment bit set in its IP header. It attempts to guess the initial Time To Live for the packet by rounding it up to the next nearest power of 2, because many system types have a TTL of 2^n or $(2^n)-1$. Finally, Nmap analyzes the explicit congestion notification behavior of the target machine to see how it handles the extended control bits associated with congestion control.

- Takes screenshots of websites, VNC and RDP servers
- Can be very effective to sort through hundreds of different websites
- Attackers and testers look for default pages, out-of-date servers, RDP servers which show domains, index-able directories, etc.
- Many vulnerabilities are not necessary vulnerabilities which have a Metasploit module
 - Finding backup files and install scripts on web servers can lead to easy access to external systems
- Developed by Chris Truncer
 - <https://github.com/ChrisTruncer/EyeWitness>

When attacking websites one of the larger tasks for the bad guys, and good guys testing their systems, is trying to identify what is running on hundreds, if not thousands of web servers. To get around this issue an attacker can run an excellent tool called EyeWitness. This tool will take a screenshot of every web server it detects. It is based on the initial *PeepNtom* research of Tim Tomes with Black Hills Information Security. This can be used to very quickly identify the purpose of multiple websites simply by reviewing the pictures.

What an attacker is looking for are things like default pages, management pages and pages which may be serving up index-able files to the Internet. Remember, there is more to attacking a network than simply discovering ports and looking for an exploit.

Below is a nice usage guide:

<https://www.christophertruncer.com/eyewitness-2-0-release-and-user-guide/>

Get it here:

<https://github.com/ChrisTruncer/EyeWitness>

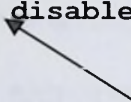
- **Preparation**
 - Close all unused ports by shutting off services and applying filters
 - Utilize stateful packet filters and/or proxy firewalls
 - Utilize an intrusion detection system
- **Identification**
 - Several IDS signatures for port scans
 - Log analysis shows pesky connection attempts
- **Cont, Erad, Recov: N/A**

When you bring a new system online, you should be familiar with the ports that are open on the box and why they are required.

The only way to be secure is by using a Defense-in-Depth posture. In addition to the information in the slide, utilize an intrusion detection system.

- Kill running process using Taskmgr (be careful)
- Or use `wmic process [pid] delete`
- Disable service in Service Control panel
 - Start→Run and type "services.msc"
 - Hit Stop
 - Set Startup type to "Disabled"
- Or, use the "sc" command
 - For a list of services, type `C:\> sc query`
 - To shut off a service, type `C:\> sc stop [service]`
 - To disable a service, type `C:\> sc config [service] start= disabled`
- Be careful

Don't forget that space
after "start="



Once you find listening ports, you need to evaluate whether the given network service is required on the box.

If the service is not needed, you can disable it temporarily, abruptly, and unsmoothly by killing the associated process in Task Manager (if there is a single associated process). Be careful with this maneuver, because it could make your system highly unstable. Also, the process may return when you reboot the system.

A cleaner way to disable a listening port, if the listening process was started as a Windows service, involves disabling the service itself. You can do this by running the Services control panel, which is easily invoked from Start→Run and typing services.msc. Then, double-click the offending service, hit Stop, and set its Startup Type to "Disabled."

If you are more of a command-line person, you can do the same thing using the Service Controller command, "sc." To get a list of services and their status, type "sc query." To stop a service, type "sc stop [service]" (this works only temporarily; the service returns at reboot). To permanently disable a service, type "sc config [service] start= disabled." Remember, you must have a space after the "start=" and before the "disabled" or the syntax doesn't work. Also, you cannot have a space between the start and the =.

Finally, please, please, please be careful with this. If you disable a crucial service, you could make your system highly unstable.

- Kill running process using kill or killall (be careful)
- Disable service by reconfiguring inetd or xinetd
 - **inetd**: Comment out lines in /etc/inetd.conf
 - **/etc/xinetd.d**: Delete file or make sure it contains "disable=yes"
- Disable service by altering /etc/rc.d files or running systemd (which alters rc.d automatically)
systemctl list-units --type service
systemctl disable <service>
- Be careful not to kill critical processes

To stop a process on Linux or UNIX, you can use the "kill [pid]" or "killall [process_name]" commands. Be careful with these, because they could make your system unstable. Also, this only temporarily disables the process. It may restart automatically or during the next boot.

The process for disabling a service listening on a port permanently depends on whether the service is invoked by inetd, xinetd, or one of the service initialization scripts.

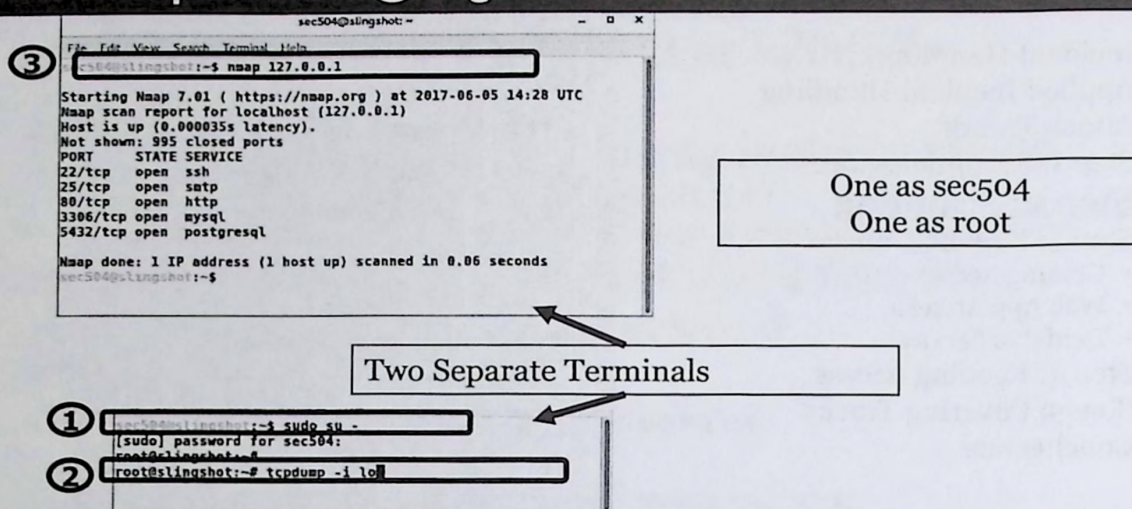
If the service is started by inetd, you can comment out its line in /etc/inetd.conf by placing a "#" at the beginning of the line.

If the service is started by xinetd, you can delete the file /etc/xinetd.d/[service] or edit that file so that it contains a line that says "disable=yes."

You can also list and disable services using the systemctl utility.

Please, be careful disabling services. Always take a moment to verify that you are not disabling a critical system process.

Lab: Nmap as sec504@slingshot



SANS

SEC504 | Hacker Tools, Techniques, Exploits, & Incident Handling 106

When you first log in to your 504 VM, you are logged in as the sec504 account.

First, we open a simple terminal by select the terminal icon on the desktop. Note that, when you first log in, your command prompt is a dollar sign. Now, let's open a second terminal (by once again clicking the terminal icon on your desktop) and becoming root with the following command:

1. `$ sudo su -`

When asked for a password, enter the password of sec504. Now, note we have two separate terminals with two separate levels of access open at the same time. The terminal on the left has you logged in as student and the terminal on the right is logged in as root. Note that root is a powerful account and one should always be careful when running your system with this level of access.

Next, we start a sniffer in the second (root@slingshot) terminal. This allows us to see the different Nmap scans and how the packets are different from each other based on options and privilege level.

2. `# tcpdump -i lo`

Now, let's start a basic Nmap scan in the first (sec504@linux) terminal. The goal of having both of these windows open at the same time is to see the stimulus (the Nmap scan) and the response (the tcpdump output).

3. `$ nmap 127.0.0.1`

Lab: Getting More Information

```
root@slingshot:~# nmap -A 127.0.0.1

Starting Nmap 7.01 ( https://nmap.org ) at 2017-06-05 14:32 UTC
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000041s latency).
Not shown: 995 closed ports
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 7.2p2 Ubuntu 4ubuntu2.2 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   2048 a7:58:1b:ce:eb:1a:72:77:9a:36:58:45:9e:02:77:4b (RSA)
|_  256 b8:9d:ae:4b:13:0d:81:4e:87:2d:a1:03:ca:e1:8e:4b (ECDSA)
25/tcp    open  smtp         Exim smtpd 4.86_2
|_ smtp-commands: slingshot Hello localhost [127.0.0.1], SIZE 52428800, 8BITIME, PIPELINING, PRDR, HELP,
|_ Commands supported: AUTH HELO EHLO MAIL RCPT DATA NOOP QUIT RSET HELP
80/tcp    open  http         nginx 1.10.0 (Ubuntu)
|_ http-headers:
|_  http-headers: Volume /
|_  maxfiles limit reached (10)
|_  SIZE      TIME      FILENAME
|_  -         31-May-2017 04:42  SEC504/
|_  -         31-May-2017 04:42  SEC504/vsagent-504/
|_  -         29-May-2017 14:30  SEC560/
|_  -         29-May-2017 14:30  SEC560/CourseFiles/
```

SANS

SEC504 | Hacker Tools, Techniques, Exploits, & Incident Handling 108

Although identification of ports is a good thing, today's modern attacker (and incident handler) needs more data. For example, in book one, we discussed the importance of being able to identify ports and services across entire environments. We do this for two reasons: 1) to possibly identify vulnerable services, and 2) we may want to identify possible backdoors the bad guys are using.

Nmap has a powerful option called `-A`. This option enables OS detection, version detection, script scanning, and traceroute. It gives you far more information than a simple syn or TCP connect scan.

Let's run it now:

```
1. # nmap -A 127.0.0.1
```

Note: This takes a while to run.

As you can see, it provides us with not only the ports but also now identifies the full-service version (such as nginx 1.6.2). It also queries the services to identify what commands it supports (for example, smtp-commands). This is critical because there will be times when Nmap does not have a proper fingerprint for a service. In these situations, it provides you with banner information for the service. With this information, an incident handler can then do a Google search of the banner information Nmap provides and, in some situations, discover a new backdoor on your environment.

Optional Lab: 65,536? (I)

- All major operating systems have 65,536 ports
 - 16 bits
- We should not always simply take this for granted
- How can we test this?
- Possibly start a listener on a higher port?
 - Will that even work?
 - If it does, what is it actually doing?
- Let's give it a shot and see what happens
- By discovering fringe odd issues, we develop possible security bypass techniques.

For a lot of security, we make basic assumptions about how computers are supposed to work. We take certain rules for granted and we never go about testing and validating them.

Let's spend a few moments and see if we can bend or possibly break the 16-bit/65,536 port rule.

Doing things like this is important because these types of fringe issues can be used to possibly bypass security products

Optional Lab: 65,536?

```

root@slingshot: ~
File Edit View Search Terminal Help
sec504@slingshot:~$ sudo su -
[sudo] password for sec504:
root@slingshot:~$ nc 127.0.0.1 70000
Did this work?
It appears it did other terminal
sec504@slingshot:~$
root@slingshot:~$ nc -l -p 70000
sec504@slingshot:~$
root@slingshot:~$ nc -l -p 70000
sec504@slingshot:~$
File Edit View Search Terminal Help
sec504@slingshot:~$ nmap -sT -p 1-70000 127.0.0.1
Starting Nmap 7.01 ( https://nmap.org ) at 2017-06-07 21:43 UTC
Ports specified must be between 0 and 65535 inclusive
QUITTING!
sec504@slingshot:~$ nmap -sT -p 1-65535 127.0.0.1
Starting Nmap 7.01 ( https://nmap.org ) at 2017-06-07 21:43 UTC
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000029s latency).
Not shown: 65529 closed ports
PORT      STATE SERVICE
22/tcp    open  ssh
25/tcp    open  smtp
80/tcp    open  http
4444/tcp  open  unknown
Nmap done: 1 IP address (1 host up) scanned in 1.48 seconds
sec504@slingshot:~$

```

Let's test this further.

First, let's kill the existing session by pressing Ctrl+c to kill the netcat listeners.

Then, restart the listener.:

```
# nc -l -p 70000
```

Now, in a new window, lets kick on an nmap scan testing up to 70,000 ports.

```
$ nmap -sT -p 1-70000 127.0.0.1
```

Annnnnnddd it did not work.

Let's just try a full port scan.

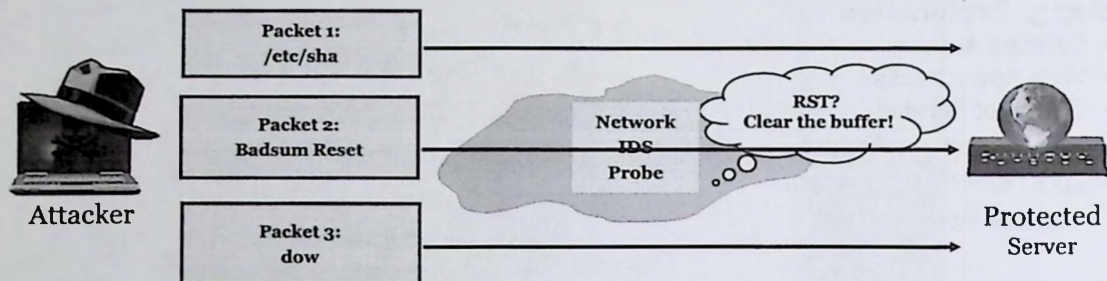
```
$ nmap -sT -p 1-65535 127.0.0.1
```

As you can see, there is one odd port, 4464. What is that? Well, it turns out that 70,000 – 4464 = 65,536. The port wrapped. This is because the port number in netcat is an unsigned integer. It will just wrap over the address space. While neat. How useful is this? It turns out, these kinds of tricks are what security researchers do to bypass security products. Let's say there is an endpoint security product that is watching command line arguments for a number between 1-65536. With this trick, you may be able to bypass such a product. Remember, if you run this more than once, you need to restart nc each time.

Invalid TCP Checksum Bypass

Evading IDS/IPS

- Many IDS/IPS systems do not validate the TCP checksum
 - Too much overhead
- An attacker can insert a TCP Reset with an invalid checksum to clear the IDS/IPS buffer
- Target systems drop any packet with an invalid TCP checksum



SANS

SEC504 | Hacker Tools, Techniques, Exploits, & Incident Handling 114

An outstanding bypass discovered by Judy Novak involves sending a Badsum TCP Reset packet in the middle of an attack. This works because of the difference in the way a target operating system handles TCP checksums and the way many firewall/IDS/IPS systems handle the TCP checksum. According to the checksum RFCs, if a packet is received with an invalid TCP checksum, it is to be dropped. This is because nothing in the packet can be trusted.

However, many IDS/IPS/firewalls do not calculate the TCP checksum because of the processing overhead involved with checking this for every packet. So, if they receive a TCP Reset, they believe the session will be closed. So, they flush the buffer relating to that specific stream. If attackers can have their attacks signature bridge two packets and have a TCP Reset packet with an invalid TCP checksum split the two halves of the attack, they stand a good chance that their attack will bypass the IDS/IPS system.

- **Preparation**
 - Keep your IDS and IPS up to date
 - Supply IDS and IPS with recommended resources (network performance, processor, RAM, and hard drive)
 - For sensitive systems, use host-based IDS in addition to network-based IDS and IPS
 - Implement User Behavioral Analytics
 - Utilize Host Based IDS/IPS
- **Identification**
 - IDS signatures indicate heavy fragmentation or overlapping TCP Segments
 - IPS can block odd packets fragments
- **Cont, Erad, Rec: N/A**

To avoid these problems, make sure that your systems reassemble packet streams before making filtering or intrusion-detection decisions. A firewall can do this, imposing its impression of the reassembly before the IDS, IPS, and end system get the packet. Everything after the firewall has the same interpretation of the packet because the reassembly by the firewall forces the segments into a single packet stream. However, the best approach is running a host based IDS/IPS on Internet facing systems.

There is another side of this as well, the behavioral side. There are a number of products which can detect user logons from odd locations and detect multiple concurrent logons as well. The User Behavioral Analytics product space is designed for detecting this type of behavior.

Also, make sure that you carefully follow your vendor's specifications for the processing power, RAM, network, and other performance characteristics for your IDS sensors and IPS tools. Those analytic capabilities require resources to keep up with the attacker's tricks.

Of course, a minimal set of absolutely required ports should be open in the first place. This minimizes the chance that an attacker will find a sensitive port through scanning with or without fragments.

Vulnerability Scanners

- Vulnerability scanning tools help map a network, scan for open ports, and find various vulnerabilities
- Test against a list of known exploits
 - What about the unknown
 - That's why we want to have security in-depth
 - Multi-layered, sound architecture needed
- Generate pretty reports
 - Information overload
 - What do you do with a 2,000-page report

Vulnerability scanning tools are extremely useful because they automate security checks across a large number of systems over the network. However, understand their limitations:

- The tools only check for vulnerabilities that they know. They cannot find vulnerabilities that they don't understand.
- The tools tend to be flat: They look for vulnerabilities, but most cannot exploit them and pivot beyond an initial surface target to find other targets and vulnerabilities. A real attacker applies a great deal of intelligence to try to reverse engineer your network. Instead of just looking at outside interfaces, intelligent attackers try to understand what's going on behind them.
- The tools often don't perform detailed correlation among many vulnerabilities to ascertain overall risk. You may have low-risk vulnerability A, low-risk vulnerability B, and low-risk vulnerability C, each of which, by itself, is low risk. However, because you have all three present in a given way in your environment, you may face a high risk. Most vulnerability assessment tools cannot perform that kind of analysis, although a real-world computer attacker may.

- We focus on Nessus, the most popular vulnerability scanner
 - Commercial license for all commercial use
 - Free home-use license
- Project originally started by Renaud Deraison, now run by Tenable Network Security
- Available at www.tenable.com/products/nessus
- Nessus consists of a client and server with modular plug-ins for individual tests

Nessus is a very useful tool. For this course, we look at it in detail, because it remains one of the most popular vulnerability scanners. Nessus is offered via two different license mechanisms. The commercial Nessus license is for all commercial use of the Nessus product and costs US\$1,200 per year per Nessus server. Tenable also makes available a free home-use license, but this license prohibits its use in commercial environments; instead, it is to be used for non-commercial home scanning.

The Nessus project was originally started by Renaud Deraison, who went on to co-found Tenable Network Security with other information-security industry luminaries.

Nessus is a client-server architecture with a large number of plug-ins that measure targets for individual vulnerabilities.

- The Nessus server is available for
 - Linux, FreeBSD, MacOS X, and Windows
- The server is accessed and configured using a browser, which runs an HTML5-based client
- Of course, client and server can run on the same machine, which is the most common use case
- Some plug-ins are characterized as "dangerous"
 - They may impact targets with crashes or locked-out accounts
 - Some of the plug-ins in the Denial of Service family of plug-ins are dangerous; others are not, because they merely check version number
 - "Safe Checks" is the GUI option that turns off dangerous plug-ins
 - These dangerous plug-ins are disabled by default

The Nessus server is available on many variations of Linux, FreeBSD, Mac OS X, and Windows. The Nessus client runs inside of any HTML5-capable browser, such as Firefox, IE, or Chrome.

Most people run the Nessus client and server on the same machine, as we do in this class for the next lab.

Nessus includes the concept of "dangerous" plug-ins, which could impair a target system, making it crash or otherwise unstable. Some dangerous plug-ins could likewise lock out accounts, resulting in a Denial of Service condition for legitimate users.

Some of the plug-ins in the Denial of Service family of Nessus plug-ins are dangerous, while other plug-ins in that category are not. The non-dangerous Denial of Service plug-ins typically just check the version number of a target service and indicate whether there is a known Denial of Service attack against that version, without actually launching the attack. That's why they aren't dangerous. But, the dangerous plug-ins in the Denial of Service family actually launch the attack, potentially causing problems for the target system.

In the Nessus GUI, the "Safe Checks" option ensures that dangerous plug-ins are not run in a given scan. This Safe Checks option is activated by default, which means that dangerous plug-ins are turned off in the default configuration of Nessus.

- Preparation
 - Close all unused ports
 - Shut off all unneeded services
 - In Windows, stop or delete services in Services control panel, as discussed earlier
 - In UNIX, edit /etc/inetd.conf or /etc/xinetd.d files, as well as rc.d files (remember chkconfig from earlier)
 - Apply all system patches
 - Keep up-to-date
 - Run credentialed scans of your environment
 - **Review results sorted by plugin ID!! Not by IP address!!**
- Identification
 - Utilize intrusion detection system signatures
 - Most vulnerability scanners trip hundreds of signatures
- Cont, Erad, Rec: N/A

Again, this is not rocket science. Still, it is difficult to keep up with all the patches on numerous types of systems. However, we must keep our critical systems patched and up to date.

The following are some key defense measures one can take.

Close all unused ports by shutting off all unneeded services.

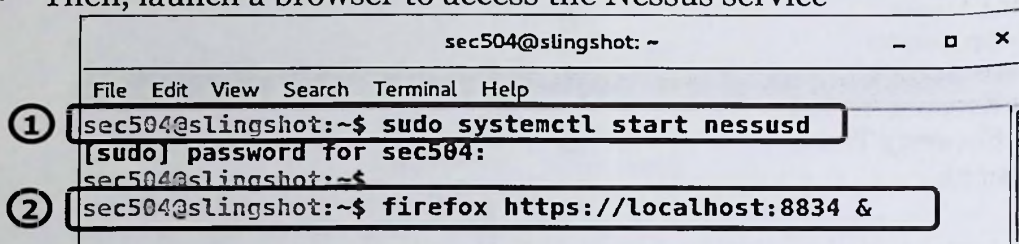
You should also export results by plugin ID instead of IP address. While you may have 1,000s of systems with dozens of vulnerabilities, you will only have a few hundred vulnerability groups which will have multiple systems in those groups. This way, you can identify systematic vulnerabilities and come up with a unified approach to addressing them.

Make sure that you keep your systems up to date by applying all system patches. You can easily test this by running scanning tools using something called credentialed scans. These scans use a valid user ID and password to access a server and validate configuration and patches.

Finally, utilize an intrusion detection system, which specializes in detecting this type of scanning tool.

Lab: Invoking Nessus

- Nessus consists of two parts
 - **Nessus daemon (nessusd)**: Runs as a service
 - The server that does the scanning
 - **Nessus client**: Accessed using a browser to connect via HTTPS to port 8834 on the nessusd system
- First, start the Nessus service on your Linux image
- Then, launch a browser to access the Nessus service



```
sec504@slingshot: ~  
File Edit View Search Terminal Help  
① sec504@slingshot:~$ sudo systemctl start nessusd  
[sudo] password for sec504:  
sec504@slingshot:~$  
② sec504@slingshot:~$ firefox https://localhost:8834 &
```

Next, let's conduct a lab using Nessus. As a reminder, we are starting a service, so this requires you to be root. To become root, enter 'sudo' and then sec504's password of sec504

First, in the course VMware Linux image, start the Nessus service:

```
$ sudo systemctl start nessusd
```

Although an "OK" message will NOT appear, the service starts when you get a command prompt back.

We use the web-based interface as a Nessus client, so launch the Firefox browser to connect to your localhost on port 8834 using HTTPS:

```
$ firefox https://localhost:8834 &
```

Note the site is HTTPS. The S is important.

The & at the end of this command will kick the browser process into the background so we can get our terminal command prompt back. If you receive some Glib errors, that is OK. As long as the Firefox window opens you are fine.

Lab: Loading a Scan

Scans My Scans

Name

① 504_Scan

Scans Hosts Vulnerabilities Remediations Notes History

Severity	Plugin Name	Plugin Family	Count
CRITICAL	OpenSSH < 7.0 Multiple Vulnerabilities	Misc	1
CRITICAL	PCI DSS compliance	Policy Compliance	6
CRITICAL	FTP Privileged Port Bounce Scan	FTP	5
CRITICAL	ProFTPD Username Variable Substitution SQL Injection	FTP	5
CRITICAL	smartipd Multiple Vulnerabilities (Traversal, DoS)	FTP	5
CRITICAL	Xlight FTP Server Authentication SQL Injection	FTP	5
CRITICAL	Firewall UDP Packet Source Port 53 RuleSet Bypass	Firewalls	1

128

To get started, we first select the 504_Scan already loaded for you. If you have time, start a scan of the local system after the core steps of the lab are done.

Next, select “Vulnerabilities.” This loads the results in such a way as to sort the output by vulnerability ID rather than by IP address. This is important because far too many organizations try to sort their vulnerabilities by IP address. This seems like a good idea at first but is often impossible to address at scale. Why? Well, as you see later, it is far quicker and easier to see a large number of vulnerabilities when they are stacked. Service banners are good this way. However, if you were to sort by IP address, then you would have to review the same vulnerability ID or category multiple times for each IP address. Sorting by Vulnerability allows us to quickly and efficiently review a large number of vulnerabilities.

Record Your Results Here

Vulnerability	Host(s)	Original Risk Rating	Actual Risk Rating

Feel free to use this for your notes.

Lab:TFTP

18262 (5) - TFTP Traversal Arbitrary File Access

Synopsis

The remote TFTP server can be used to read arbitrary files on the remote host.

Description

The TFTP (Trivial File Transfer Protocol) server running on the remote host is vulnerable to a directory traversal attack that allows an attacker to read arbitrary files on the remote host by prepending their names with directory traversal sequences.

Solution

Disable the remote TFTP daemon, run it in a chrooted environment, or filter incoming traffic to this port.

Risk Factor

passwd

Medium

CVSS Base Score

5.0 (CVSS2#AV:N/AC:L/Au:N/C:P/I:N/A:N)

CVSS Temporal Score

4.1 (CVSS2#E:F/RL:OF/RC:C)

```
root:x 0 0 root root /bin/bash
bin:x 1 1 bin root /bin/bash
daemon:x 22 daemon root /bin/telnet
adm:x 2 4 adm root /bin/telnet
lsh:x 4 7 lsh root /bin/telnet
sync:x 5 5 sync root /bin/telnet
chroot:x 6 6 chroot root /bin/telnet
root:x 7 7 root root /bin/telnet
root:x 41 41 root root /bin/telnet
root:x 42 42 root root /bin/telnet
root:x 43 43 root root /bin/telnet
root:x 44 44 root root /bin/telnet
root:x 45 45 root root /bin/telnet
root:x 46 46 root root /bin/telnet
root:x 47 47 root root /bin/telnet
root:x 48 48 root root /bin/telnet
root:x 49 49 root root /bin/telnet
root:x 50 50 root root /bin/telnet
root:x 51 51 root root /bin/telnet
root:x 52 52 root root /bin/telnet
root:x 53 53 root root /bin/telnet
root:x 54 54 root root /bin/telnet
root:x 55 55 root root /bin/telnet
root:x 56 56 root root /bin/telnet
root:x 57 57 root root /bin/telnet
root:x 58 58 root root /bin/telnet
root:x 59 59 root root /bin/telnet
root:x 60 60 root root /bin/telnet
root:x 61 61 root root /bin/telnet
root:x 62 62 root root /bin/telnet
root:x 63 63 root root /bin/telnet
root:x 64 64 root root /bin/telnet
root:x 65 65 root root /bin/telnet
root:x 66 66 root root /bin/telnet
root:x 67 67 root root /bin/telnet
root:x 68 68 root root /bin/telnet
root:x 69 69 root root /bin/telnet
root:x 70 70 root root /bin/telnet
root:x 71 71 root root /bin/telnet
root:x 72 72 root root /bin/telnet
root:x 73 73 root root /bin/telnet
root:x 74 74 root root /bin/telnet
root:x 75 75 root root /bin/telnet
root:x 76 76 root root /bin/telnet
root:x 77 77 root root /bin/telnet
root:x 78 78 root root /bin/telnet
root:x 79 79 root root /bin/telnet
root:x 80 80 root root /bin/telnet
root:x 81 81 root root /bin/telnet
root:x 82 82 root root /bin/telnet
root:x 83 83 root root /bin/telnet
root:x 84 84 root root /bin/telnet
root:x 85 85 root root /bin/telnet
root:x 86 86 root root /bin/telnet
root:x 87 87 root root /bin/telnet
root:x 88 88 root root /bin/telnet
root:x 89 89 root root /bin/telnet
root:x 90 90 root root /bin/telnet
root:x 91 91 root root /bin/telnet
root:x 92 92 root root /bin/telnet
root:x 93 93 root root /bin/telnet
root:x 94 94 root root /bin/telnet
root:x 95 95 root root /bin/telnet
root:x 96 96 root root /bin/telnet
root:x 97 97 root root /bin/telnet
root:x 98 98 root root /bin/telnet
root:x 99 99 root root /bin/telnet
root:x 100 100 root root /bin/telnet
```

132

Start looking at scanner results as less of a roadmap of what exactly needs to be done, but as your eyes and ears on a target network. Trivial File Transfer Protocol (TFTP) is a good example of this. When Nessus runs, it attempts to pull the /etc/passwd file via TFTP. In this situation, it succeeded. Arbitrary file access is bad. In addition to grabbing /etc/passwd, it could also grab config files from the web server or backend databases.

Often in our testing, simple file access is one step away from a total server takeover.

Lab: Telnet

Telnet Server Detection

Description

The remote host is running a Telnet server, a remote terminal server.

Solution

Disable this service if you do not use it.

Output

Here is the banner from the remote Telnet server :

```
----- snip -----
Login:
----- snip -----
```

Port	Hosts
23/tcp/telnet	10.10.10.130, 10.10.10.132, 10.10.10.133, 10.10.10.134

Here is the banner from the remote Telnet server :

```
----- snip -----
router>
----- snip -----
```

Port	Hosts
23/tcp/telnet	10.10.10.135

Here is the banner fr

router>

134

It is often the case where dozens, if not hundreds, of systems, will be running the exact same service. For example, telnet is still often enabled on Internet-facing systems to this day. It may even be intentional. For example, some ISPs use Telnet for remote management of their routers. If configured properly, they ask for a user ID and a password. However, if viewed properly, you can see how systems are clustered. In section 1 of the slide, you see a large number of Telnet servers with the prompt "Login:". This would be expected. Not ideal, but expected. However, in section 2, you see there was one with a prompt of "router>," which means there is no authentication necessary for this router. Again, this is an informational vulnerability, which is actually quite critical.

Course Roadmap

- Incident Handling
- Applied Incident Handling
- Attack Trends
- Step 1: Reconnaissance
- **Step 2: Scanning**
- Step 3: Exploitation
 - Gaining Access
 - Web App Attacks
 - Denial of Service
- Step 4: Keeping Access
- Step 5: Covering Tracks
- Conclusions

Scanning

1. War Dialing
2. War Driving
 - Lab: Wireless LAN Discovery with InSSIDer
3. Network Mapping with Nmap
4. Port Scanning with Nmap
 - Lab: Nmap
5. Evading IDS/IPS
6. Vuln Scanning with Nessus
 - Lab: Nessus
7. **SMB Sessions**
 - Lab: SMB Sessions

An additional scanning technique lets an attacker grab data from a Windows environment across Server Message Block (SMB) sessions. This powerful technique allows an attacker to grab information about available users, groups, shares, and more, all by using a non-admin username and password. We look at a variety of tools to pull this information, especially enum for Windows and rpcclient for Linux. We also perform a hands-on lab to illustrate the technique.

- On Windows machines, the `net use` command establishes a session

```
C:\> net use \\[TargetIP]
```

 - The currently logged-on user's credentials are sent via pass-through authentication
 - The default administrative share is selected (typically `ipc$`, but other shares such as `admin$`, `c$`, or others may be connected)
- To connect as another user or to a specific share, use

```
C:\> net use \\[TargetIP]\[ShareName] [password] /u:[UserName]
```

 - That user does not need to be in the admin group to connect to `ipc$` or other open shares (although `c$` and `admin$` require admin privs)
 - If you leave off the `[password]`, Windows prompts you for it
- To connect as no user (an anonymous or NULL SMB session), use

```
C:\> net use \\[TargetIP] "" /u:""
```

 - A NULL SMB session has a blank username and password

To establish an SMB session from one Windows machine to another at a given target IP address, type the following at the command line:

```
C:\> net use \\[TargetIPAddr]
```

Because we have not provided a username in this command, the current user running the "net use" command has his or her authentication credentials passed through to the target machine. So, for example, if user "bob" runs this command on Windows machine A, that Windows machine attempts to authenticate as bob to the `TargetIPAddr`.

Also, because we have not put in a share to connect to after the `TargetIPAddr`, Windows tries to connect to the next available admin share, which is typically `IPC$`, a share used for remote access of system information.

If we want to connect as a different user or to a specific share (such as `IPC$`, `ADMIN$`, `C$`, or a user-specified file share on the target), run this more general command:

```
C:\> net use \\[TargetIPAddr]\[ShareName] [password] /u:[UserName]
```

Note that the user does not have to be in the admin group to connect to most available shares, such as `IPC$`. That is, you can establish an SMB session to most Windows targets as long as you have a non-admin username and password. Some shares (notably `C$` and `ADMIN$`) require admin privileges to which to connect. If you leave off the password in this command, you are prompted for it.

Some Windows machines support the concept of a NULL SMB session. With a NULL session, the username and password fields are blank, essentially making them anonymous. A NULL SMB session can be established with the following command (note the blank password and username):

```
C:\> net use \\[TargetIPAddr] "" /u:""
```

Older versions of Windows (such as Windows NT and 2000) allow for detailed interrogation of a target machine across NULL SMB sessions with their default configurations. More recent versions of Windows may still allow NULL SMB sessions to connect, but they block the enumeration of configuration information across the NULL session.

- Show shares and systems
 - C:\> net view
- Users
 - C:\> net user /domain Put users from above into users.txt
- Now, we crack passwords
 - C:\> @FOR /F %n in (users.txt) DO @FOR /F %p in (pass.txt) DO @net use \\DOMAINCONTROLLER\IPC\$ /user:DOMAIN\%n %p 1>NUL 2>&1 && @echo [*] %n:%p && @net use /delete \\DOMAINCONTROLLER\IPC\$ > NUL

When we test, we often use these first three net commands to gain access to a large number of systems.

The first command is used to identify sensitive systems and shares. We are particularly interested in file shares.

Next, we look for users. The net user command (shown in slide) pulls all the domain users.

Finally, we take the users and load them into a file called users.txt and create a limited password file called pass.txt. The number of passwords should be less than the account lockout threshold of the environment.

Finally, we have a FOR loop that passed the users (%n) and the passwords (%p) into the net use command where we are trying each combination to authenticate against a domain controller.

- Backdoor built in PowerShell
- Fantastic post-exploitation scanning abilities
- Family of modules under Situational Awareness
 - situational_awareness/network/sharefinder: Find accessible shares
 - situational_awareness/network/arpscan: ARP Scan the local IPv4 systems
- Also has the ability to map domain trusts, group membership, portscan and conduct reverse DNS lookups
- Uses built in Microsoft Protocols like SMB
- Get it here:
 - <http://www.powershellempire.com/>



PowerShell Empire is easily one of the more disruptive tools to hit the security industry in quite some time. The reason for this is because it is built purely in PowerShell, which is installed on most Windows systems by default. By using the built-in functionality of Windows there is tremendous power in what you can do post-exploitation to scan for additional vulnerabilities and systems to compromise. For example, situational_awareness/network modules will allow an attacker to easily enumerate shares and users across a domain. Dramatically reducing the amount of time needed to find sensitive shares and documents on the inside of a network.

It can be found here:

<http://www.powershellempire.com/>

- Use the smbclient tool to establish an SMB session from Linux to Windows
- To list available shares

```
$ smbclient -L [WinIPAddr] -U [username] -p 445
```

 - Enter the password when prompted
- To connect to an SMB share and pull files interactively (behaving like an FTP client)

```
$ smbclient //[Win IP addr]/test -U [username] -p 445
```

 - Enter the password when prompted
 - You get an "smb: \>" prompt
 - Use "ls" for directory listing, "cd" to change directories, and "get" to get files
 - Type ? for a list of additional commands

Besides Enum running on Windows to attack Windows, we can also pull information from target Windows machines using a Linux system. In particular, the smbclient program that is part of the Samba suite can pull a list of shares from a target Windows box by running

```
$ smbclient -L [WinIPAddr] -U [username] -p 445
```

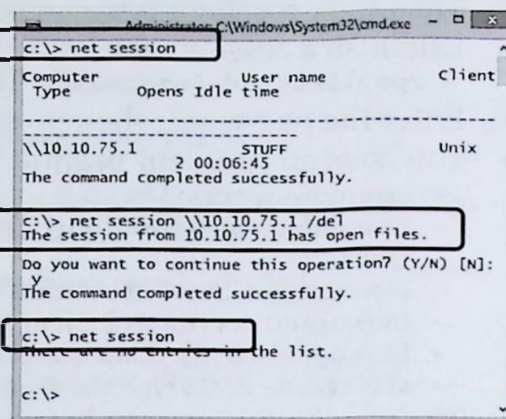
Alternatively, you can use smbclient to make an *interactive* SMB connection to a target Windows machine and then push files to or pull them from the target. When connecting to an SMB share, this smbclient tool provides an interactive command prompt that is reminiscent of an FTP client, letting you navigate the directory structure with cd, get a directory listing with ls and pull files with the get command. To make an interactive smbclient connection, you'd run the following command (which includes ls and get afterward of examples of things you might do):

```
$ smbclient //[Win IP addr]/test -U [username] -p 445
Enter [username]'s password:
smb: \> ls
smb: \> get [filename]
```

Seeing and Dropping SMB Sessions

SMB Sessions

- On Windows, to see where you have established outbound SMB sessions (you are acting as an SMB client), run
`C:\> net use`
- To drop an outbound SMB session, run
`C:\> net use \\[IPaddr] /del`
- On Windows, to see who has established inbound SMB sessions (you are acting as an SMB server), run
`C:\> net session`
- To drop an inbound SMB session, run
`C:\> net session \\[IPaddr] /del`



```
Administrator: C:\Windows\System32\cmd.exe
C:\> net session

Computer      User name      Client
Type          Opens Idle time
-----
\\10.10.75.1   STUFF          Unix
              2 00:06:45
The command completed successfully.

C:\> net session \\10.10.75.1 /del
The session from 10.10.75.1 has open files.
Do you want to continue this operation? (Y/N) [N]:
Y
The command completed successfully.

C:\> net session
There are no entries in the list.

C:\>
```

SANS

SEC504 | Hacker Tools, Techniques, Exploits, & Incident Handling 146

On a Windows machine, to see which SMB sessions you've made outbound to other systems (for example, when you are acting as a Windows client for SMB), you can run the "net use" command by itself, as follows:

```
C:\> net use
```

The output displays the target machine and the share to which you are connected. To drop an outbound SMB session to the given IPaddr, you could run

```
C:\> net use \\[IPaddr] /del
```

If you want to drop all outbound SMB sessions (instead of just one associated with a given IP address), you could run

```
C:\> net use * /del
```

When prompted, if you want to delete all sessions, type y and press Enter. Or you could append /y to your command, and you won't be prompted.

Flipping things around, let's discuss how you can list and drop SMB sessions that are opened inbound to your system (for example, you are acting as a Windows SMB server). To list the inbound sessions (as shown in the slide's screenshot), you could run

```
C:\> net session
```

Then, to drop an inbound SMB session, you could run

```
C:\> net session \\[IPaddr] /del
```

The ability to drop individual SMB sessions (inbound or outbound) can be useful for incident handlers because doing this can temporarily stop an attacker from using the SMB session. This introduces a small pause in the attacker's progress, perhaps buying you some time.

- Preparation (cont.)
 - Block access to the following ports across network boundaries and local firewalls where SMB sessions are not required for admin or file share usage:
 - **TCP/UDP 445:** MS Server Message Block
 - **TCP 135:** RPC/DCE Endpoint mapper
 - **UDP 137:** NetBIOS Name Service
 - **UDP 138:** NetBIOS Datagram Service
 - **TCP 139:** NetBIOS Session Service
 - Of course, block all ports except those required
 - Alternatively, allow access to these ports only from systems or networks that absolutely require SMB access to a given destination (such as file servers and domain controllers)
 - Private VLANs (PVLANS) are a switch feature that can help implement this
- Identification
 - Check for access to the ports listed above in logs and IDS alerts
- Cont, Erad, Rec: N/A

Typically, you need to allow SMB sessions only from clients to a specific set of servers (such as file servers and domain controllers). Usually, you don't need clients to establish SMB sessions to other clients. Thus, you can implement some solid defenses by configuring routers and firewalls to block SMB sessions with TCP port 445, as well as the NetBIOS ports TCP and UDP 135 through 139. Allow such traffic only to specific systems where there is a business need for SMB.

Some organizations deploy client systems on Private VLANs (PVLANS), a switch feature that provides them a major degree of control over what goes into and out of the network interface connecting to each individual host. With PVLANS, you could block all inbound SMB to client machines and allow outbound SMB only to specific servers.

Lab: SMB Sessions with net use, smbclient, and rpcclient

- Use your Windows and Linux systems for this lab
- Lab goals
 - Open and list SMB sessions with "net use" and "net session"
 - Make smbclient and rpcclient connections from Linux to Windows
 - Enumerate the target with rpcclient on Linux
 - Drop SMB sessions
- Make sure that your Windows machine is ready
 - We return to some common defaults

We now do a lab associated with SMB sessions, establishing them to and from our Windows machines.

Our goals are to open and list SMB sessions with "net use" and "net session," enumerate all kinds of information on our target Windows machines using enum on Windows, use the Linux smbclient and rpcclient tools to make SMB sessions, enumerate detailed data with rpcclient, and then drop SMB sessions.

These skills are helpful for incident handlers and are often used by computer attackers. You also rely on them on the Day 6 Workshop.

Using smbclient to Get a List of Shares

```
sec504@slingshot: ~  
File Edit View Search Terminal Help  
sec504@slingshot:~$ smbclient -L 10.10.0.1 -U sec504  
WARNING: The "syslog" option is deprecated  
Enter sec504's password:  
Domain=[SEC504STUDENT] OS=[Windows 10 Enterprise 14393] Server=[Windows 10 Enterprise 6.3]  
  
Sharename      Type      Comment  
-----  
ADMIN$         Disk      Remote Admin  
C$             Disk      Default share  
IPC$           IPC       Remote IPC  
Connection to 10.10.0.1 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)  
NetBIOS over TCP disabled -- no workgroup available  
sec504@slingshot:~$
```

We start by using smbclient on Linux to pull a list of shares from Windows. Type the following command:

```
$ smbclient -L 10.10.0.1 -U sec504
```

When prompted, type your sec504 account's password.

You should see a list of shares on the Windows box, including ADMIN\$, IPC\$, and C\$. These are the default admin shares that the Windows "net view" command hides by default. But smbclient can see them. You may see additional shares if you created any.

You may also see some warning messages at the bottom of the output (as shown on the slide's screenshot), including "Called name not present," "NetBIOS over TCP disabled," and more. You can safely ignore these. The share list is the focus of this lab.

Enumerating Server Info and Groups

```
sec504@slingshot: ~  
File Edit View Search Terminal Help  
rpcclient $> srvinfo  
10.10.0.1 WK SV NT PtB Sec504Student  
platform_id : 500  
os version : 10.0  
server type : 0x11003  
rpcclient $> enumalsgroups domain  
group:[Ssh Users] rid:[0x3e9]  
rpcclient $> enumalsgroups builtin  
group:[Access Control Assistance Operators] rid:[0x243]  
group:[Administrators] rid:[0x220]  
group:[Backup Operators] rid:[0x227]  
group:[Cryptographic Operators] rid:[0x239]  
group:[Distributed COM Users] rid:[0x232]  
group:[Event Log Readers] rid:[0x23d]  
group:[Guests] rid:[0x222]  
group:[Hyper-V Administrators] rid:[0x242]  
group:[IIS_IUSRS] rid:[0x238]  
group:[Network Configuration Operators] rid:[0x22c]  
group:[Performance Log Users] rid:[0x22f]  
group:[Performance Monitor Users] rid:[0x22e]  
group:[Power Users] rid:[0x223]
```

SANS

SEC504 | Hacker Tools, Techniques, Exploits, & Incident Handling 154

Let's use rpcclient to enumerate server info:

```
rpcclient $> srvinfo
```

Here, you see the IP address and the OS version.

Now, let's get a list of groups. First, we pull domain-related groups (typically groups created on the local machine either by an admin there or within the domain):

```
rpcclient $> enumalsgroups domain
```

Remember, the "als" in the middle of enum and groups stands for "alias."

Next, we pull internal groups (typically the default groups defined by Microsoft):

```
rpcclient $> enumalsgroups builtin
```

Together, these are all the groups defined on the machine. Note that we have the group names and their RIDs in hexadecimal form.

Look at Outbound and Inbound SMB Sessions and Delete a Session

Administrator: Command Prompt

```
C:\Windows\system32>net use
```

New connections will be remembered.

There are no entries in the list.

```
C:\Windows\system32>net session
```

Computer	User name	Client Type	Opens	Idle time

\\10.10.75.1	sec504		5	00:01:50

The command completed successfully.

```
C:\Windows\system32>
```

SANS

SEC504 | Hacker Tools, Techniques, Exploits, & Incident Handling 156

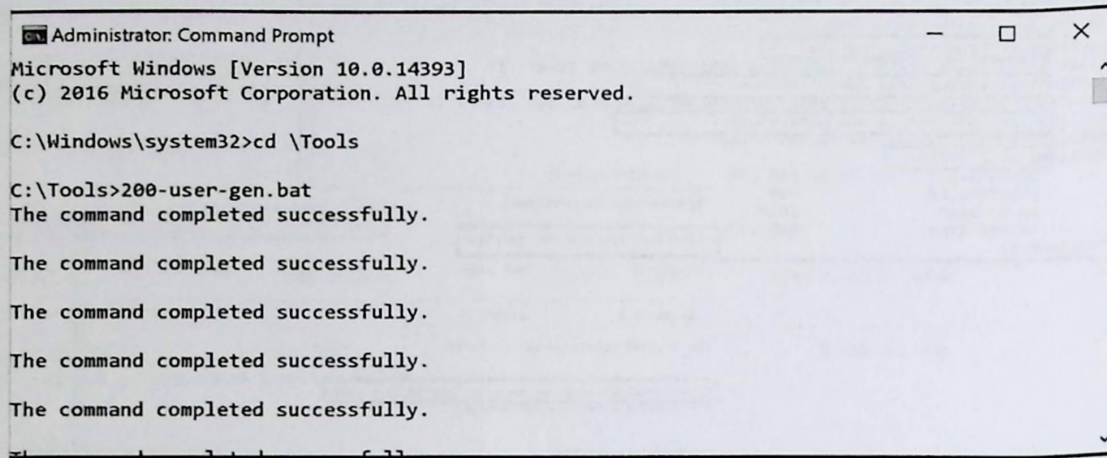
Now, let's look at our outbound SMB session (where we're acting as a Windows SMB client):

```
C:\> net use
```

Now, let's look at the inbound SMB session (where we're acting as a Windows SMB server):

```
C:\> net session
```

SMB Lab: Finding Weak Passwords (I)



```
Administrator: Command Prompt
Microsoft Windows [Version 10.0.14393]
(c) 2016 Microsoft Corporation. All rights reserved.

C:\Windows\system32>cd \Tools

C:\Tools>200-user-gen.bat
The command completed successfully.

The command completed successfully.

The command completed successfully.

The command completed successfully.

The command completed successfully.
```

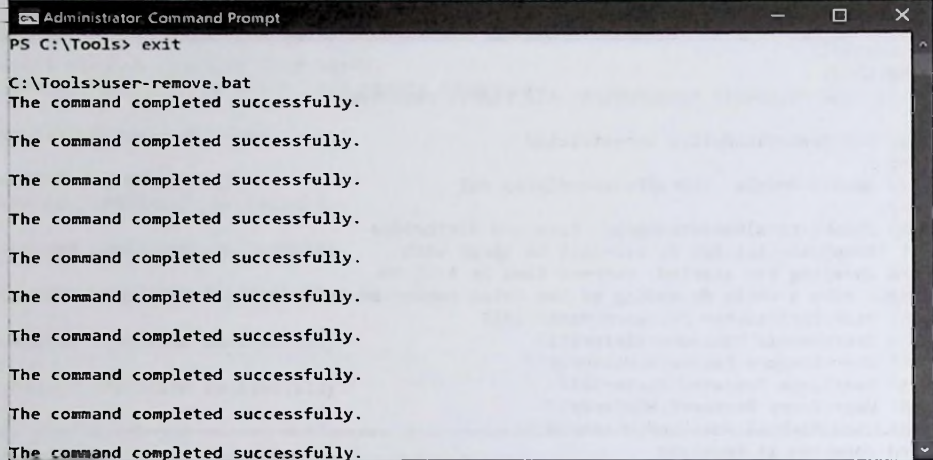
Next, we are going to see just how dangerous SMB access can be.

For this part of the lab we are going to create 200 users with a simple user generation script, then attack the passwords.

```
C:\> cd \Tools
C:\Tools> 200-user-gen.bat
```

If you see lots of The command completed successfully messages, it means the script is working. If you got errors, double check you are running your command prompt as an administrator.

SMB Lab: Cleaning Up



```
Administrator: Command Prompt
PS C:\Tools> exit

C:\Tools>user-remove.bat
The command completed successfully.

The command completed successfully.

The command completed successfully.

The command completed successfully.

The command completed successfully.

The command completed successfully.

The command completed successfully.

The command completed successfully.

The command completed successfully.

The command completed successfully.
```

SANS

SEC504 | Hacker Tools, Techniques, Exploits, & Incident Handling 160

When you are done guessing passwords, let's clean up your system of the temp accounts.

To do this, we need to first exit PowerShell:

```
PS:\>exit
```

Then, we need to run the user-remove.bat script:

```
C:\>user-remove.bat
```

Lab Conclusions

- In this lab, we covered how to
 - Create Windows accounts at the command line
 - Make SMB sessions with the Windows "net use" command
 - Analyze and drop SMB sessions with "net use" and "net session"
 - Use Linux rpcclient to enumerate users, groups, group membership, and other detailed account information
 - These are immensely useful capabilities for attackers... and incident handlers

In conclusion, in this lab, we've seen some of the power of SMB sessions, particularly in harvesting information from target Windows machines. We covered how to make and drop SMB sessions at the Windows command line. We looked at interrogating Windows machines using enum from Windows. We also looked at how to use smbclient and rpcclient on Linux to gain detailed information from target Windows machines.

The best part of this is that it can all be done with just a single username and password on the target system, even if that user does not have admin privileges on the target box.

Attackers use these capabilities on a regular basis, and incident handlers can also benefit from them as they analyze the security settings of systems in their environments.